

DECISION AUDIT

CloudTMS Candidate App

Current Agreed Decisions

Audit date	12 August 2026
Status	Approval-ready current-decision register
Scope	DB/RPC → backend/private API → public broker → CloudTMS frontend → iPhone/Android/web
Rule	Current decisions only; superseded positions removed

How to approve this document

Read the short sections as the current product handbook. Exact route-warning and rejection wording appears once near the end. Anything not genuinely settled is isolated under Decisions still to be approved.

Contents

1. System ownership and boundaries
2. Environments, access and security
3. Candidate accounts and authentication
4. Entitlement, navigation and history
5. Route families and candidate capability
6. CONTRACT weekly timesheets
7. DAILY booked shifts and timesheets
8. Local Save for Later
9. Expense entry and evidence
10. Expense claim lifecycle
11. Expense separation, carriers and invoice routing
12. Electronic submission and official documents
13. Manager approval
14. Paper signing and QR lifecycle
15. Processing, authorisation, payment and invoice progression
16. Rejection, amendment and no-work
17. Notifications and communication
18. Candidate App functional layout
19. CloudTMS office presentation
20. Route conversion and office intervention
21. Concurrency, recovery and audit
22. Delivery order and verification
23. Route-conversion warning catalogue
24. Decisions still to be approved
25. Omissions and limitations
26. Source precedence used for this audit
27. Office switch to Manual: incomplete expense claims
28. Exact replay and PAPER execution authority
29. Authentication and operation-replay closure
30. Public credential replay and push-token identity
31. Public authentication boundary, replay and key rollout
32. Final public-authentication throttle and key authority
33. Mixed-version concurrency ownership
34. Credential winner and security receipt

This register contains current decisions only. Superseded wording is excluded. Anything not fully approved is isolated in Decisions still to be approved.

Approval summary

This document contains the current controlling decisions only. Earlier positions that were later changed have been removed rather than repeated. The original policy, UI specification, presentation addendum, later audit instructions, route-warning catalogue, installed DB/RPC authority and current backend plan were reconciled before drafting it.

The overall design is now:

- CloudTMS owns all canonical timesheet, financial, evidence, processing, authorisation, invoice and route truth.
- The Candidate App is a controlled new interface over CloudTMS, not a second timesheet or finance system.
- The database/RPC authority, CloudTMS Candidate backend, separate public Candidate broker and private Candidate API foundation are installed/deployed in TEST with every Candidate feature flag disabled; independent final API-freeze verification remains the next gate.
- The CloudTMS office frontend and Candidate iPhone/Android/responsive-web interface remain to be implemented against the finally approved contract.
- Seven Candidate App tables and fourteen public Candidate business RPCs are the fixed architectural limit. No duplicate current function definitions are permitted in the installable SQL set.

The items under **Decisions still to be approved** are the only matters this audit could not honestly classify as already agreed. They concern implementation technology, branding/publishing details and pixel-level app presentation—not the core CloudTMS timesheet policy.

1. System ownership and boundaries

CloudTMS remains the sole authority for contracts, contract weeks, timesheets, TSFIN, evidence, route validity, processing, authorisation, invoice locks, payment locks, retained financial history, deletion, archive and invoice routing.

The Candidate App and its broker submit factual information only: actual starts and finishes, breaks, additional units, expense claim amounts and source evidence. They never supply authoritative rates, pay, charge, VAT, ERNI, margin, invoice breakdown, TSFIN totals, issue codes, import classification or authorisation eligibility.

All candidate-facing channels and office-facing CloudTMS screens must receive the same server decision for the same facts. Frontend controls may guide a user, but the backend/database revalidates the final proposed state under lock.

The following existing CloudTMS authorities remain the only authorities for their jobs:

- the existing WEEKLY calculation and lifecycle path;
- one shared canonical DAILY Save/Recalculate calculation body used by office create, office edit, additional DAILY, the TSFIN worker and Candidate finalisation;

- the existing Process functions, with `timesheet_daily_manual_process_atomic` remaining Process-only;
- the existing Authorise authority;
- the existing Invoice Generator/Issuer pipeline;
- one SQL route/version authority;
- one official CloudTMS timesheet renderer with controlled document variants;
- one manager workflow and approval authority used by both phone and email presentation routes.

Candidate-specific expense placement, evidence, approval, rejection and notification orchestration may remain bounded Candidate workflow logic. It must compose the existing financial and lifecycle authorities and must not duplicate their calculations.

The retained Google Availability/rota service remains responsible for the existing DAILY rota and availability behaviour. DAILY rota data is not migrated into a new CloudTMS rota system.

Banking Pay, Policy X, payment execution, settlement, remittance, PAYE/Umbrella economics, rate calculations and the legacy Google DAILY business behaviour are outside this project and must not change.

2. Environments, access and security

TEST and LIVE are separate environments with separate broker deployments, application identities, storage, secrets, push credentials and CloudTMS/database authorities. The Candidate App initially uses TEST and later uses the separately configured LIVE environment. Any environment mismatch fails closed.

The iPhone app, Android app, responsive candidate web app and public manager pages communicate only with the separate public Candidate broker. They do not access Supabase, CloudTMS database tables, R2, Google Apps Script, Google Sheets, email providers or push providers directly.

The broker communicates with a versioned private Candidate API owned by the CloudTMS backend. It may also mediate the retained Google Availability API for DAILY rota functions.

The seven Candidate tables force row-level security. Browser roles have no direct Candidate table access, and Candidate business RPCs are service-owned rather than browser-callable.

Every protected request is bound to its environment, account, selected candidate and current session. Manager tokens are hashed, time-limited, version-bound and single-use. Mutations use idempotency keys and expected row/workflow versions so retries cannot create duplicate claims, carriers, workflows, evidence, emails, notifications or submissions.

Source evidence, generated review documents, signatures, returned signed documents and final signed documents are immutable and auditable. Route changes may supersede them as current truth, but must not physically purge signed or issued history.

3. Candidate accounts and authentication

All Candidate App users start with a new Candidate App password. Existing Google password hashes and salts are not migrated or used as a legacy login path.

The email must exist on an eligible CloudTMS candidate record. Activation and password recovery begin with an enumeration-safe email challenge so the public response does not reveal unnecessary account information.

First activation consists of creating and confirming a new password, receiving an email verification code, verifying that code and creating the first session. Password establishment and first-session creation are one transaction: a person cannot be left with a password but no completed activation session.

CloudTMS creates and verifies the modern password credential. Plaintext passwords are never sent into SQL. Access tokens are short-lived; refresh tokens are opaque and rotated; only refresh-token hashes are stored. Presenting an old token after rotation triggers token-family replay protection and revocation.

One login can access only candidate records whose normalised CloudTMS email matches the authenticated email. In TEST, where more than one matching record exists, the user selects the candidate record they are using. LIVE must not permit duplicate active candidate accounts sharing one email.

Switching the selected candidate resets all server and local candidate context. No timesheet, draft, notification or rota information from the previous selection may remain visible.

Change Password, Notification Preferences and Logout are app-level Account actions. They are not buried inside the DAILY menu.

4. Entitlement, navigation and history

DAILY entitlement requires the selected active candidate to have a non-empty Global Candidate Key in `candidates.key_norm`. The server rechecks entitlement when a DAILY workflow is created and again at finalisation; hiding a DAILY card is not sufficient authority.

The retained Google Candidate_ID continues to identify rota/booking data. It does not replace the CloudTMS GCK or become the login authority.

CONTRACT entitlement exists when the selected candidate has an eligible contract-week or timesheet occurrence in the current six-calendar-month window. Unprocessed, processed, authorised, invoiced and paid occurrences all count for entitlement.

App-level navigation contains Home, DAILY/Rota where entitled, CONTRACT Timesheets where entitled, Notifications and Account. Home shows a large DAILY card and/or CONTRACT card. If only one module is available, the app may open it directly while keeping an app-level way to switch module.

The Timesheets page uses **Current** and **History** tabs. **Current** is selected by default.

Current. Starting with each contract's effective current week ending and moving backwards, it shows every not-paid timesheet with no age limit, including unprocessed, processed, authorised, rejected or action-required, and invoiced-but-not-paid records. It also shows a paid timesheet while its authoritative `paid_at_utc` is within the preceding seven days. No later contract week or genuinely future timesheet appears.

History. Shows paid timesheets older than seven days within a 16-week window: the effective current contract week and the preceding 15 contract weeks, calculated separately for each contract. A timesheet appears in one tab only.

Both tabs order cards strictly by week-ending date from most recent to oldest. Each card displays **Week Ending 1 January 2025**. Archived rows never appear; different contracts appear separately.

Canonical financial state wins over historical workflow state when producing the visible status. Paid and authorised states cannot be hidden by an older rejected, refused or awaiting workflow. Workflow audit history remains available separately from the Current and History tabs.

Each CONTRACT row provides candidate-safe display facts without the broker querying CloudTMS tables directly: client, week-ending day/date, job title, band, stable status, route/capabilities, hours, expense overlay, manager state, rejection scope/reason and invoice/payment state.

5. Route families and candidate capability

The server assigns one effective route family for every materialised timesheet in this order:

1. import-authoritative;
2. actual current QR/paper facts;
3. ELECTRONIC submission authority;
4. otherwise genuine MANUAL non-QR.

The app and future broker consume the returned route and capability flags. They do not infer route from `submission_mode`, a paper-fallback setting or raw QR fields.

Import-authoritative and genuine MANUAL non-QR hours are candidate view-only. The candidate cannot start or finalise hours, declare no work or mutate those records. Import-authoritative expenses use the mandatory separate expense route.

Paper fallback permission does not transform an existing MANUAL non-QR timesheet into a candidate paper timesheet. A QR/paper route requires actual route/version facts or a valid new route intent.

Candidate PAPER/QR is WEEKLY-only. DAILY always uses electronic manager approval by phone and/or email and never gains a Candidate paper route.

An unsigned DAILY row may remain physically MANUAL to preserve the existing two-signature database constraint, while a constrained server-owned pending route intent records that it is logically awaiting a fresh ELECTRONIC submission. That intent is consumed by reads, workflow creation, finalisation and office route context, then cleared when the final signed ELECTRONIC row is created.

Route/capability authority is rechecked at list/detail, missing-week creation, workflow creation, worker submission, paper preparation, expense placement, no-work and finalisation.

6. CONTRACT weekly timesheets

The backend returns all seven authoritative dates from the contract-week snapshot and effective week-ending rule. The app never assumes the week ends on Sunday and shows days even when no work was planned.

Non-ad-hoc contracts prepopulate the effective planned schedule. Ad hoc shifts start without schedule prepopulation. Candidates may change permitted start/finish times, add or remove multiple segments on the same day, enter overnight work and enter breaks as start/finish or duration.

The existing WEEKLY authority remains responsible for overlap checks, date boundaries, daylight-saving behaviour, time buckets and every financial value.

A candidate can explicitly record **No break**. The canonical factual input is `break_minutes = 0` with no break start or finish. WEEKLY accepts this without creating the DAILY-specific non-60-minute break issue.

Additional Units appear only where the contract supports them. Any non-zero Candidate-entered additional units are HOURS-side content, require office checking and block automatic authorisation. They also count as worked activity when deciding whether an expense claim can be made for that week.

There is no percentage-deviation calculation for WEEKLY Additional Units. They have no agreed scheduled baseline against which a percentage comparison can be made. Percentage-based unexpected-hours checking applies only where this document explicitly defines a planned-versus-actual hours rule; it must not be extended to WEEKLY Additional Units.

Candidates can submit a complete timesheet without entering expenses. The app offers [Continue with Timesheet Only](#) or equivalent approved wording and explains that expenses may be added later. An unfinished receipt or mileage form never blocks an otherwise complete hours submission.

[Add missing week](#) is available only for an eligible ELECTRONIC or candidate-enabled WEEKLY paper route where the full seven-day week overlaps the candidate's contract. It is unavailable for import-authoritative or MANUAL non-QR routes and cannot duplicate an existing/hidden base week. Effective settings are resolved separately for each generated week. A successful request uses the existing CloudTMS contract-week/planning authority to create the ordinary base week: [OPEN](#) when the week has reached the current Europe/London date, otherwise [PLANNED](#). The Candidate App introduces no separate missing-week lifecycle or creation engine.

[I did not work this week](#) is available only on a candidate-operable, unprotected WEEKLY record. It uses the existing planned-week delete, materialised-record delete or retained-history archive authority as appropriate. It creates no new no-work tombstone.

7. DAILY booked shifts and timesheets

The existing Google-backed availability tiles, status choices, booked shifts, refresh, Past Shifts, running-late/emergency functions, Hospital Addresses and Accommodation Contacts remain functionally unchanged. Their appearance may later be improved, but their communication semantics and Google-side behaviour do not change.

The existing retained DAILY availability application/service and existing DAILY timesheet integration remain operational and unchanged throughout Candidate App TEST and pilot unless replacement is separately approved. The new Candidate broker may mediate the retained Google Availability API, but this project is not authority to decommission or modify either retained DAILY deployment during TEST/pilot.

The ordinary DAILY timesheet entry is a booked, eligible, not-authorised shift tile. The old generic [Send a timesheet by email](#) menu item is removed.

Opening a shift shows date, client/site, ward, role, booking reference and booked start/finish. The candidate is asked whether those hours are correct. Yes reuses the booking; No opens actual start/finish controls while keeping the booked values visible.

The candidate records a break using start/finish, an explicit duration, or **No break**. No break is stored as zero minutes with no start or finish. The factual value is accepted by the canonical DAILY calculation and existing TSFIN route.

The normal planned break used for DAILY deviation comparison is 60 minutes unless a more specific authoritative planned break exists. If planned net time cannot be resolved safely, automatic authorisation is withheld rather than guessed.

A DAILY actual break other than 60 minutes—including an explicit no-break value of zero—creates the DAILY checking issue. The app shows the calculated duration and says office checking may delay payment, with [Change Break Times](#) and [Yes, Continue](#). The actual break is preserved when the candidate continues.

Unexpected-hours comparison is performed per Europe/London work date. Multiple planned segments are combined, planned breaks are subtracted, multiple actual segments are combined and actual breaks are subtracted. The issue is raised only when actual daily net minutes are strictly greater than planned daily net minutes by more than the current configured percentage. Exactly at the threshold, fewer hours and under-reporting do not trigger this issue. Positive actual work against zero planned net time does.

The same Europe/London work-date derivation is used by DAILY read, workflow creation, schedule validation, issue calculation and finalisation, including overnight and daylight-saving boundaries.

The candidate reviews one shift and signs it. The manager methods are controlled by Care Packages settings: phone, email or both; at least one must be enabled. DAILY manager name and position are entered each time and are never prepopulated.

The functional Care Packages settings remain [Allow manager to authorise on phone](#) and [Allow manager to authorise by email](#). CloudTMS must reject a settings save that would leave both disabled. The configured hours-deviation percentage remains settings-owned and server-enforced; it is never exposed as an editable Candidate value.

DAILY contains no expenses, mileage, expense evidence, Candidate paper/QR, later expense claim or Add missing week. The app never displays the internal deviation percentage.

Final DAILY materialisation follows one sequence: save the frozen manager-approved factual schedule through the shared canonical DAILY Save/Recalculate owner, obtain the fresh row signature, call the existing Process authority, then call the existing Authorise authority only when automatic authorisation is allowed. The economic calculation itself is unchanged.

HealthRoster DAILY validation remains authoritative. Where validation is required, Candidate finalisation must not call Authorise and the existing validation/READY_FOR_HR route continues.

8. Local Save for later

Save for later is entirely local and makes no broker or CloudTMS mutation. Native apps use protected application storage; the responsive web app uses candidate-bound IndexedDB.

The local draft may hold hours, breaks, additional units, expense values, evidence images, mileage progress and current screen progress. It is not visible on another device, to a manager or in CloudTMS.

The draft remembers the last server context. If the contract, route, settings or row version changes, the candidate must review the draft before continuing.

If hours are submitted while an expense draft remains unfinished, only the submitted hours part is cleared. The local expense draft remains under [Continue Expense Claim](#) and may be removed with [Discard Expense Claim](#). Discarding it removes only unsent local information.

The confirmation is [Saved on this device](#). [Nothing has been submitted yet](#). Returning to a draft offers [Continue Draft](#) and [Discard Draft](#).

9. Expense entry and evidence

The candidate claims only the needed categories: Mileage, Accommodation, Travel and Other, plus any later category that is already supported by canonical CloudTMS economics. Zero fields for unused categories are not required.

Category choice may remain optional to the candidate where the current screen makes the context unambiguous. For example, evidence uploaded inside the Accommodation flow can be labelled Accommodation by the server without asking the candidate again. The immutable server component must nevertheless always contain exactly one derived category. A conflicting caller-supplied category is rejected.

Travel, Accommodation and Other require at least one valid source image for that category. Mileage requires a completed Mileage Claim Form. Evidence requirements are derived from all accepted economic fields—units, pay values, charge values and general expense values—so an alternate or negative economic field cannot bypass the rule.

One uploaded source component supports exactly one category. Several clear receipts may appear in one photograph, and multiple components may support the same category. Candidate source evidence may be a validated image/photo or a dedicated one-page PDF for that category. Mixed-category evidence and multi-page candidate evidence PDFs are not accepted.

The backend computes the authoritative content hash. The same image bytes cannot be reused as another claim, category, week or generation. When evidence already exists, a different image must be identified as additional or replacement evidence.

No expense amount becomes canonical until the relevant workflow has the required evidence, manager approval is complete, every required final signed page is ready and atomic finalisation succeeds.

The Expense and Mileage Approval Summary does not count as Other source evidence. Generic TIMESHEET evidence and generated unsigned documents are not automatically treated as signed returned evidence.

Only one active TIMESHEET evidence item may exist for a timesheet. More than one source image per expense category remains supported.

Mileage Claim Form

When mileage is entered, the app asks whether the candidate already has a completed and signed Mileage Claim Form. If not, it offers Download, Email to Me, Save for Later and—during initial hours entry—Submit Timesheet Now and Finish Mileage Later.

The branded A4 form is titled `Mileage Claim Form for week ending DD/MM/YYYY`. It contains Date, Postcode From, Postcode To and Number of Miles, with Total Mileage prepopulated and Manager Name, Position, Signature and Date at the bottom. A returned form is canonical MILEAGE evidence with document role `MILEAGE_CLAIM_FORM`.

The returned Mileage Claim Form is handwritten evidence, not a machine-readable economic source. CloudTMS does not automatically interpret or reconcile handwritten journey rows against the candidate-entered or prepopulated mileage total. Suspected discrepancies use the existing manual office review and whole-record rejection/correction process.

Expense and Mileage Approval Summary

When any mileage or expense exists, CloudTMS generates one branded A4 summary for the actual expense record. It identifies candidate, client, contract and week, lists each non-zero total and shows evidence counts by category. It requires one manager name, position, signature and server date but no candidate signature.

The summary uses evidence kind OTHER with document role `EXPENSE_MILEAGE_APPROVAL_SUMMARY`. It never creates an Other amount, never satisfies Other source evidence and appears only once in invoice evidence.

10. Expense claim lifecycle

Candidates may add expenses during the initial timesheet flow or return later to the visible worked row. Hours do not need to be resubmitted for a later standalone expense claim.

When `Add Expenses` is selected for a worked week that already has an expense claim, the app first shows candidate-safe information about that claim: previously submitted amounts/categories, submitted date, evidence count and current status where available. With no prior claim it starts a new claim. With an active claim it offers `Continue Existing Claim` or `Cancel Entire Claim and Start Again`. After an authorised/completed claim it may offer a subsequent claim under the rules below. Paid or invoiced history creates a new generation, shows `Requires Checking for Duplicate` and prevents automatic authorisation.

A candidate may have only one not-yet-authorised expense claim for the same candidate, contract and worked week. This remains true after the first claim is finalised but still unauthorised. Concurrent attempts are serialised so only one succeeds.

An active claim offers `Continue Existing Claim` or `Cancel Entire Claim and Start Again`. Cancellation invalidates outstanding manager links and generated paper documents while retaining immutable audit history.

Another claim can start only after the previous canonical expense claim is actually authorised. A later claim after paid or invoiced history uses a new generation, displays `Requires Checking for Duplicate` and never auto-authorises.

Worked eligibility uses the authoritative predicate: positive clock-hours **or** positive additional units. Expense-only carrier rows remain hidden; there is no standalone expense card in the Candidate App.

11. Expense separation, carriers and invoice routing

Expense separation is mandatory for NHSP import-authoritative hours and HealthRoster CREATE/no-timesheet-required hours. It cannot be disabled. A valid effective Expense Invoice Email is required when import-authoritative client or contract settings are saved.

For optional non-import routes, the functional setting is `Send expense-only invoices to a different email address`. When enabled, separation applies, an effective valid Expense Invoice Email is required, expenses use a separate expense-only record where the policy requires it and only the expense-only invoice uses that address. For import-authoritative routes, `Separate expense invoicing is required`; it cannot be disabled and an effective valid Expense Invoice Email is mandatory.

For other routes, separation is controlled by the effective client/contract setting. Where contract settings do not override the client, the client value applies. Where contract override is active, an explicit contract value—including false—wins. Import authority always overrides an attempt to turn separation off.

The existing fields remain the internal storage to minimise change:
`send_manual_invoices_to_different_email` is the separation switch and
`manual_invoices_alt_email_address` is the Expense Invoice Email.

Where separation applies, the proposed final economic state classifies a mutable additional row:

Final state	Server role
Hours or additional units non-zero; expenses zero	Hours
Expenses/mileage non-zero; hours and additional units zero	Expenses
Both sides zero and no active expense evidence	Flexible
Both sides non-zero	Conflict and reject

Positive and negative values count as non-zero. Protected import, correction, authorised, paid, invoiced, archived or retained-history rows are not silently reclassified because a current total happens to be zero.

On a flexible mutable row, both sides may initially be available. Entering hours, schedule segments or additional units disables expenses and expense evidence. Entering mileage or expenses disables schedule and additional-unit controls. Clearing one complete side can make the other available again; the UI never silently deletes values or evidence.

When separation is off and the current timesheet is mutable, expenses may use it. When separation is required, CloudTMS reuses exactly one eligible expense carrier for the same candidate/contract/week or creates one atomically through the existing additional-timesheet authority. It never reuses an additional-hours, ambiguous, authorised, paid, invoiced or archived row.

Each hidden expense carrier is resolved to a visible display anchor independently: active workflow anchor, then `parent_timesheet_id`, then a unique base worked row, then a unique additional worked row. Zero possible anchors or more than one possible anchor fails closed; the server never guesses the first row.

Only economically expense-only invoices use the Expense Invoice Email. Hours and hours-only adjustments use the normal invoice route. Negative expense corrections use the Expense Invoice Email; negative hours corrections remain on the normal route.

Expense-only sources do not consolidate with hours/import/self-bill sources. They may consolidate with one another only when client, recipient, effective policy and consolidation mode match. Stream and recipient are resolved before grouping, so a mixed-recipient invoice cannot be created.

A separate expense-only invoice associated with import-authoritative work remains independently sendable to the effective Expense Invoice Email. It must not inherit, and must not be suppressed by, a self-bill or no-send rule applying to the corresponding imported-hours source.

The existing Invoice Generator/Issuer READY/BLOCKED and diagnostic systems remain the visible workflow. A missing Expense Invoice Email blocks only the affected expense work; unrelated ready work continues. No separate Candidate expense invoice engine or visible internal stream labels are added.

Approved and barred manager domains are trimmed, lowercased, stripped of one leading @, syntax-validated and deduplicated.

The configured hours-deviation percentage and barred public manager-email domain list remain settings-owned server authorities. Their values and defaults are not re-derived or hard-coded independently by the Candidate App, broker or CloudTMS frontend.

12. Electronic submission and official documents

The workflow types have these fixed page/signature requirements:

Workflow	Candidate signature	Official hours page	Expense pages
CONTRACT hours	Required	Required	None
CONTRACT combined	Required	Required	Required
CONTRACT standalone expense	Not required	Forbidden	Required
DAILY	Required	Required	Forbidden

The candidate signs the exact immutable factual submission. Where manager approval is needed, CloudTMS stores a pending versioned workflow rather than prematurely committing canonical financial truth.

For every electronic hours workflow, CloudTMS renders the official one-page timesheet twice from the same immutable submission:

- the manager-review version contains exact WEEKLY or DAILY facts and the candidate signature/date, but no manager signature or approval date;
- the final signed version contains the identical business content and candidate signature plus manager name, position, one manager signature and authoritative server approval date.

The manager reviews CloudTMS-generated documents. The broker or manager page does not redraw a timesheet from JSON.

Every required review component—hours page where applicable, expense summary, mileage form and each evidence page—must be rendered, stored, hashed and present in the immutable all-ready manifest before a manager email request is created. The manager does not wait for review images/documents to be generated after opening the link.

After manager approval, final signed derivatives may render asynchronously. Approval is committed first and remains durable if rendering/finalisation fails. The office can retry final rendering/finalisation

idempotently without asking the manager to sign again. Canonical finalisation occurs only when every required final signed derivative is ready.

13. Manager approval

Phone and email are two presentations over the same workflow generation, required component manifest, approval request, signature event and finalisation authority.

The manager is told how many pages must be reviewed. They review the official hours page where present, Expense and Mileage Approval Summary, Mileage Claim Form and every source evidence page separately. Each required page must be recorded as viewed before approval.

The manager does not sign each page. After all pages are reviewed, the manager confirms/enters name and position and draws one signature. That signature and the server approval date are applied to every page in the approval transaction.

For CONTRACT, the last approved manager name/position for the same candidate and contract may be prepopulated with **Not you? Change**, subject to current policy revalidation. DAILY never prepopulates manager identity.

Phone approval requires no manager email. Manager mode shows only the pages being approved, not the candidate account. Success shows a large green tick, **MANAGER APPROVED**, then returns to the timesheet list/rota. No separate push is sent for immediate phone approval.

After on-phone approval succeeds, control may be handed directly back to the candidate. No biometric prompt, password prompt or app reauthentication is required solely because the phone has just returned from isolated manager mode. Manager mode must remain isolated from Candidate account controls while the manager is using it.

Email approval uses one secure link for the complete workflow, including all expenses. The link lasts seven days. Each request permits the initial send plus five resends. A reminder is allowed only after 24 hours since the previous send, while the request is live and resend allowance remains.

An expired unchanged submission may be renewed with a new token and a fresh send allowance. Candidate cancellation requires a reason, invalidates the request, notifies the manager and is audited. Manager refusal also requires a reason and refuses the whole current workflow/record scope. First complete approval wins; completing phone approval invalidates a competing live email token.

Before completion, changing the approval method retires the previous active method atomically. Moving from a live email-manager request to paper signing supersedes the request and invalidates its token. Moving from an active paper-signing generation back to ELECTRONIC approval retires the paper workflow, pack and code and requires a fresh electronic generation. Only one current approval route/generation may remain live; historical requests and packs remain auditable but cannot later complete the superseded workflow.

Allowed manager email identities are the union of exact client addresses/domains and exact contract addresses/domains. Domain matching is exact; subdomains require their own entry. Client settings can allow free entry; contract settings are INHERIT, ALLOW or DISALLOW and an explicit contract value wins.

Free entry permits valid non-public business addresses. Public consumer domains are barred by the system default list unless the exact address or exact domain is explicitly approved. The agreed starter list is: gmail.com, googlemail.com, hotmail.com, hotmail.co.uk, outlook.com, outlook.co.uk,

live.com, live.co.uk, msn.com, yahoo.com, yahoo.co.uk, gmail.com, icloud.com, me.com, mac.com, aol.com, proton.me, protonmail.com, mail.com, gmx.com and gmx.co.uk.

If an office route change withdraws a live emailed request, the link is invalidated atomically. The approved email is:

Subject: Timesheet approval request withdrawn **Body:** The approval request for this timesheet has been withdrawn by CloudTMS. No further action is required.

14. Paper signing and QR lifecycle

Candidate-facing wording says [Paper signing](#) or [Print documents for signing](#); it never requires the candidate to understand QR.

When electronic approval is available, the main choice presents phone and email. Paper is behind the secondary wording [Choose another option - this process can delay payment](#), followed by [Go Back to Electronic Approval](#) and a less prominent [Continue with Printed Documents](#). When electronic approval is unavailable but candidate paper is permitted, paper is the normal route and no discouraging comparison is shown.

CloudTMS creates separate branded signing pages: the existing unsigned hours timesheet, Expense and Mileage Approval Summary where required, Mileage Claim Form where required and one evidence approval page for each source image.

The QR code appears only on the official main hours timesheet. Supplementary expense-summary, mileage-form and evidence-approval pages do not receive separate QR codes; they are bound to the same immutable workflow through their manifest page identity, generation, content hash and required order.

The candidate signs the hours page. The manager signs the hours page, summary, mileage form and every evidence approval page. The candidate uploads every expected returned page against the workflow/QR-bound manifest. A missing, duplicate, foreign or wrong-generation page fails closed; one returned page cannot complete the pack.

Paper preparation is asynchronous. The lifecycle distinguishes route active, QR code generated, durable pack ready, pack issued/sent and signed return received. A QR token or generation timestamp does not prove that a PDF exists or was issued.

The initial paper-preparation request queues the existing QR document operation and a held candidate email. The candidate does not make a second email request. The email and [documents ready](#) notification are released only after the official pack is durably ready.

While waiting, the app shows [Preparing documents](#), checks the Candidate notification feed and bounded paper-pack status endpoint while the screen is active, and refreshes on resume/push. [Download documents](#) is enabled only after server readiness. The broker streams the authorised PDF without exposing an R2 key.

A generated unsigned PDF, [manual_pdf_r2_key](#), generic document asset or generic TIMESHEET evidence does not prove a signed return. Signed-return state requires explicit current return provenance such as QR scan/signature facts, a Candidate SIGNED_RETURN component or evidence/document role that explicitly identifies a returned signed timesheet.

Paper submissions never auto-authorise. After a complete return, CloudTMS attempts canonical WEEKLY finalisation and leaves any controlled blocker in a retryable received state. An office user reviews the signed pack and uses the existing Authorise action.

Reissuing/replacing a pack retires the old active Candidate workflow, invalidates the old code/pack, creates a fresh generation/code/pack and retains all issued/signed history. Ordinary UI does not restore a revoked historical QR generation.

15. Processing, authorisation, payment and invoice progression

Electronic candidate submission creates a pending workflow; it does not immediately make candidate-entered facts canonical. Manager approval plus complete final signed documents allows atomic finalisation.

WEEKLY finalisation uses the existing WEEKLY authority and moves the contract week/current financial row into the normal submitted/PENDING_AUTH lifecycle. DAILY finalisation uses canonical Save/Recalculate, then existing Process, and reaches PENDING_AUTH.

Automatic authorisation is allowed only where the effective setting permits it and no checking blocker exists. The policy precedence is contract setting when present, otherwise client setting, otherwise the global default; the global default is false.

Automatic authorisation is withheld for applicable issues including unexpected hours, DAILY break not equal to 60 minutes, Candidate-entered additional units, HealthRoster validation, duplicate expense review and required evidence review. Those informational issues do not prevent an authorised CloudTMS office user manually authorising after review unless an existing lifecycle rule separately blocks it.

Paper is never auto-authorised. Import-authoritative hours do not enter Candidate hours approval. HealthRoster validation remains a gate where applicable.

Once authorised, the record enters the existing invoice and payment-eligibility checks. Candidate finalisation never executes payment, creates a new payment pathway or bypasses invoice readiness.

16. Rejection, amendment and no-work

Reject Candidate Submission is whole-record rejection. CloudTMS does not reject an individual receipt/page while keeping the rest of the same record active.

The action is unavailable while the record is authorised; the existing Unauthorise process must run first. It is blocked for invoiced, paid, archived or otherwise financially protected records.

For a combined hours-and-expenses record, rejection requires the candidate to resubmit the complete timesheet and every expense on that record. For a separate expense carrier, rejection applies to the complete expense claim on that carrier and does not affect the separate hours record. An hours-only record requires the hours timesheet to be resubmitted.

Successful rejection removes/supersedes the active candidate-submitted evidence and clears applicable hours, breaks, additional units, expense values, manifests, signatures and authorisation on the new/current record. The editable current lifecycle ends OPEN/UNPROCESSED. Rejected historical versions and evidence remain for audit but are not current truth. Old manager links, paper packs and QR tokens become unusable.

The candidate message states both the problem and the complete resubmission scope:

- Combined record: Your timesheet and expense claim have been rejected. Problem: [specific category/document]. Reason: [office reason]. Because the hours and expenses are stored on the same timesheet, resubmit the complete timesheet and all expenses on it. Primary action: Resubmit Timesheet and Expenses.
- Separate expense record: Your expense claim has been rejected. Your hours are not affected. You do not need to resubmit your timesheet. Resubmit the complete expense claim containing [listed amounts/categories]. Reason: [office reason]. Primary action: Resubmit Expense Claim.
- Hours-only record: Your timesheet has been rejected. Show the reason and action Resubmit Timesheet.

Awaiting-manager workflows may be cancelled or replaced as a whole. Received/processed but unauthorised amendments follow the existing CloudTMS route. An authorised record must be unauthorised first; any later Unprocess requirement remains whatever the ordinary CloudTMS lifecycle already requires. Paid/invoiced hours cannot be Candidate-amended; later expenses use a new claim generation.

17. Notifications and communication

After OS/browser permission, transactional push categories default on. Account > Notifications provides a master switch and separate controls for manager approval updates, timesheet/expense needs attention, authorisation, payment, approval reminders and resubmission required.

Turning push off never removes in-app notification truth or record badges.

Action-required notifications include manager refusal, expired approval, CloudTMS rejection and fresh route resubmission. They deep-link to the exact workflow/record and state the complete required action. They never deep-link to an individual evidence component because rejection is whole-record.

Informational notifications include manager email approval, authorisation and payment. Ordinary Received, processing and evidence upload do not generate noisy pushes. Immediate on-phone approval uses the green success screen instead of another push.

Fresh ELECTRONIC or paper resubmission notifications are idempotent. CONTRACT candidate identity is resolved from contract candidate, current TSFIN candidate, workflow candidate and only then occupant/GCK fallback; a CONTRACT candidate does not require a GCK to receive the notification.

QR documents ready and replacement-document pushes are released only after the corresponding pack is durably ready.

18. Candidate App functional layout

The agreed functional layout is clear even though final brand styling and pixel-level designs have not yet been approved.

App shell

The login screen shows agency branding, Email, Password, Sign in, First registration and Forgotten password. Home presents the entitled DAILY and CONTRACT cards. Top-level navigation also includes Notifications and Account.

Candidate screens use large touch targets, native time controls, one primary decision per screen, visible progress and Back navigation. Colour is never the only status indicator. Candidates never see carrier IDs, `additional_seq`, raw timesheet IDs, QR terminology or invoice-stream internals.

Disabled controls provide a plain-English reason and a valid next action where one exists. Review flows show page progress and Back. Validation moves focus to the first error without discarding the current work.

CONTRACT list and entry

Each card shows client, week-ending day/date, job title/band, hours total/status, expense summary/status, relevant approval/checking badge and the current View/action. Hidden expense carriers are overlaid beneath the correct worked row.

Opening a week shows all seven dates, then day/segment editing, break entry, Additional Units where configured, total review and the optional expense question. Expense entry asks `What would you like to claim?` and presents only the selected category flow. After a category, the user sees the claim summary and `Add another expense type` or `Continue`.

Approval selection presents phone and/or email according to policy. On-phone manager review is a controlled handover mode showing only the required documents. Email status shows sent time, expiry and eligible reminder/cancel actions. Paper presents one signing set but keeps each expected page separate for return.

Candidate-visible states and recovery actions

The candidate-facing status vocabulary includes, where applicable: `No timesheet submitted yet`, `Saved on this device`, `AWAITING MANAGER APPROVAL`, `Awaiting signed documents`, `Preparing documents`, `Awaiting office review`, `Received`, `Authorised`, `Paid`, `Rejected`, `Invoiced - not paid`, `Hours needs checking` and `Requires Checking for Duplicate`. Canonical paid, authorised and invoiced state takes precedence over historical workflow state.

The corresponding recovery/action vocabulary includes, where applicable: `Review & Resubmit`, `Resubmit Timesheet`, `Resubmit Timesheet and Expenses`, `Resubmit Expense Claim`, `Request Approval Again`, `Continue Existing Claim`, `Cancel Entire Claim` and `Start Again`, `Continue Expense Claim` and `Discard Expense Claim`. The server-provided capabilities and lifecycle determine which action is available; the app does not infer eligibility from the label alone.

DAILY

The existing rota tile meanings remain. An eligible booked tile shows a clear timesheet action, then the single-shift identity, booked-versus-actual hours question, break/no-break choice, review, candidate signature and permitted manager approval route. It returns to the rota when complete.

Notifications and Account

Notifications show action-required and informational items with direct navigation to the affected record. Account contains candidate selection where TEST requires it, password, notification preferences and logout.

19. CloudTMS office presentation

Existing Simple Timesheet, Timesheet Summary, Bulk Process, Bulk Authorise, Invoice Generator and Invoice Issuer remain recognisable. No replacement modal family or internal carrier-navigation scheme is introduced.

Use existing [View Related Records](#) and [Add Additional Manual Timesheet](#). Do not add Open Linked Hours/Expense buttons, general ELECTRONIC/HOURS/EXPENSES SEPARATE/LINKED badges, linked-carrier banners, a QR-signature-check badge or visible invoice-stream labels.

Approved presentation changes

- Simple Timesheet shows [Awaiting Manager Approval](#) and [Manager Approved](#) in the Overview Stage area and Issues tab. Manager Approved uses the existing positive/green style.
- Timesheet Summary shows [Awaiting Manager Approval](#), a green [Manager Approved](#) badge and [Unexpected hours - needs checking](#) using the existing warning style.
- Bulk Authorise shows red [Awaiting Manager Approval](#) and green [Manager Approved](#) in both the left-row and selected right-pane locations.
- Bulk Process uses a 4px border around the middle timesheet preview: existing success green when the viewed timesheet may be attached, existing danger red when it may not. The border has no tooltip or explanatory copy.
- Unavailable ATTACH choices remain visible but disabled. TIMESHEET is enabled only when the record can accept one and has no active TIMESHEET evidence. It is always disabled for an expense-only record.
- Bulk Process preserves row selection, list scroll, current tab, preview and evidence selection across save/process refresh, and a problem on one row does not prevent work on another eligible row.
- The existing Expenses action is disabled on a separated hours-only record. Its exact hover text is: [This timesheet cannot have expenses attached. Create an additional timesheet to add expenses.](#)
- The action label is [Reject Candidate Submission](#). The exact generic confirmation is: [This will reject the evidence submitted and require the candidate to resubmit. Are you sure you wish to continue?](#) Combined and expense-only records do not add more copy to that CloudTMS modal; the Candidate App explains scope.
- [Send Manager Reminder](#) appears in Simple Timesheet Overview > Actions. [Send Manager Reminders](#) appears next to Focus in the Timesheet Summary toolbar and operates on ticked rows. The server silently filters to eligible live email requests. The action remains visible but disabled when no selected row is eligible.
- The existing Detailed/Simple Timesheet workflow area retains candidate-safe manager workflow information where available: approval route/method, current approval status, request/send timing, expiry, resend/reminder count or remaining allowance, eligible [Send Manager Reminder](#), and

permitted cancellation status/action. This remains inside the existing timesheet UI; no replacement workflow screen or modal family is introduced.

- Invoice Generator and Invoice Issuer show the existing-style badge `Expense Email missing` where applicable. No new invoice screen or stream label is added.
- The replacement paper/QR email includes: `Please remember to sign the replacement timesheet before returning it.`

All route-conversion actions use one server preview and one shared frontend warning renderer. The first click never mutates route state. The exact warning wording is in the appendix.

No Candidate or CloudTMS warning/confirmation may use the browser or operating-system native `alert`, `confirm` or `prompt` window. The existing styled CloudTMS confirmation-modal family must be used after its exact current source function is verified. Every changed modal must be visually inspected at the supported desktop sizes and corrected if it looks untidy, clipped or inconsistent with the existing product.

20. Route conversion and office intervention

Route conversion is a server-owned preview → warning → confirm operation. Preview returns the permitted action, warning, reason requirement, current lifecycle row signature and context hash. Confirmation carries that exact signature/hash. CloudTMS locks and recomputes the context before mutation; a manager approval, authorisation, invoice lock or route change between preview and confirm produces a controlled conflict rather than a partial transition.

ELECTRONIC/QR to MANUAL is exceptional office intervention, not the normal correction route. When the candidate can simply correct and resubmit, the office uses Reject Candidate Submission. Exceptional conversion requires one closed reason:

- Candidate supplied manual timesheet;
- Candidate reported hours incorrect;
- Hiring manager reported hours incorrect;
- Electronic submission technical failure;
- Other exceptional office intervention, with a mandatory note.

Leaving an active Candidate submission atomically cancels/supersedes every matching live workflow, manager request, token and active component before the clean new route generation becomes current. More than one unexpected active workflow fails closed rather than leaving a live token behind.

MANUAL to ELECTRONIC creates a fresh unsigned logical ELECTRONIC generation, preserves factual hours/economics, reuses no old signatures/documents and notifies the worker to resubmit. MANUAL to QR creates a fresh generation, token and pack and notifies only after the pack is ready.

Ordinary QR restore actions are removed when the confirmed route feature is enabled. Exact ELECTRONIC restore is an internal-only technical undo and is available only when CloudTMS proves every component in the immutable manager-approved manifest, both signatures, final document identity and financial fingerprint are unchanged. If any required page is missing, replaced or superseded, the normal fresh ELECTRONIC route is required.

The full approved warning catalogue is reproduced once in the appendix and is controlling for the later frontend.

21. Concurrency, recovery and audit

Manager approvals for different workflows do not take a global application lock. Fifty managers approving fifty different shifts are handled independently; PostgreSQL serialises only conflicting work on the same workflow/timesheet.

A single workflow uses request/workflow idempotency, immutable manifest hashes, workflow generation and row signatures to reject double-clicks, retries and stale approvals. First complete approval wins.

Approval commits before asynchronous final rendering/finalisation. A failure on one workflow does not roll back or block unrelated approvals. The failed workflow retains durable approval and a controlled retry state; office retry does not require another manager signature.

Carrier allocation, one-claim enforcement, route changes, manager first-complete-wins, token rotation and finalisation use appropriate row/advisory locks and idempotency. No partial canonical timesheet or partial paper return is accepted.

Audit records include account, selected candidate, session, workflow generation, manager route/name/position, cancellation/rejection/intervention reason, correlation identity and CloudTMS service actor.

22. Delivery order and verification

The agreed delivery sequence is:

1. DB/RPC authority;
2. CloudTMS backend and private Candidate API;
3. separate public Candidate broker security/contract closure;
4. CloudTMS frontend;
5. Candidate App for iPhone/Android/responsive web and public manager pages.

The DB/RPC and backend stages remain part of the living implementation plan and are not discarded when later stages start. Every audit-driven correction updates that cross-stage plan so frontend, broker and app behaviour stays coherent with the installed authorities.

Every remaining implementation stage must consult this current-decisions document before changing behaviour. The latest complete PDF must be included in every Candidate App handover pack supplied for independent verification; a handover is incomplete without it.

No stage is considered complete only because code compiles. Verification includes clean PostgreSQL installation, runtime and concurrency suites, ACL and feature-off compatibility, focused and complete backend regression, frontend local-patched-asset/browser tests, route/renderer/invoice regressions, device/browser testing, accessibility, security, performance/load and an independent audit gate.

SQL handovers and repository install sets contain only the latest current schema/functions. A qualified function appears once; existing functions are replaced in their authoritative repeatable file rather than duplicated as historical alternatives.

All rollout begins in TEST. Production deployment, Candidate activation, live manager email/push delivery and app-store publication require separate explicit approval.

23. Route-conversion warning catalogue

The warning catalogue below is the exact approved copy for one shared CloudTMS frontend renderer. Warning codes are existing product/API codes, not decision-register numbering.

ELECTRONIC, nobody signed — ELECTRONIC_UNSIGNED_TO_MANUAL

Convert this timesheet to Manual?

The candidate will no longer be able to submit this version electronically. CloudTMS staff will be responsible for entering and processing the timesheet.

Use this only where the candidate has supplied the timesheet outside the electronic route, or CloudTMS staff need to intervene.

Buttons: **Go Back** / **Convert to Manual**. A mandatory intervention reason is shown before final confirmation.

Candidate signed; manager pending — CANDIDATE_SIGNED_MANAGER_PENDING_TO_MANUAL

The candidate has already signed this electronic timesheet

It is awaiting hiring-manager approval. Converting it to Manual will cancel the current electronic approval request and the manager's approval link will stop working.

The candidate's signed electronic submission will remain in the audit history but will not apply to the new Manual version.

Use **Reject Candidate Submission** instead where the candidate can simply correct and resubmit the timesheet.

Buttons: **Go Back** / **Continue to Manual conversion**. A mandatory intervention reason is shown before final confirmation.

Manager approved; CloudTMS not authorised — MANAGER_APPROVED_TO_MANUAL

The hiring manager has already signed and approved this electronic timesheet

Converting it to Manual will retire the completed electronic approval. The candidate and manager signatures and the signed electronic timesheet will remain in the audit history, but they will not apply to the new Manual version.

This action should be used only where the candidate or hiring manager has reported that the submitted hours are wrong, or another exceptional office intervention is required.

Buttons: **Go Back** / **Continue to Manual conversion**. A mandatory intervention reason is shown before final confirmation.

CloudTMS-authorised — ROUTE_CHANGE_REQUIRES_UNAUTHORISE

Unauthorise this timesheet first

This timesheet has been authorised in CloudTMS. It cannot be converted to Manual until the existing Unauthorise process has been completed. Unprocess it afterwards where the normal lifecycle requires this.

Button: **Close**. An existing Unauthorise action may be shown, but route conversion remains blocked.

Invoiced or paid — ROUTE_CHANGE_FINANCIAL_HISTORY_BLOCK

This timesheet cannot be converted

This timesheet has financial history and its submission route cannot be changed. Use the appropriate additional-timesheet, correction, credit or reversal process.

Button: **Close**.

Import-authoritative — ROUTE_CHANGE_IMPORT_AUTHORITATIVE_BLOCK

This timesheet is controlled by an import

Candidate-entered hours are not permitted for this timesheet. The submission route cannot be changed. Expenses must use the separate expense-timesheet route.

Button: **Close**.

Reject or office intervention decision

Does the candidate need to resubmit instead?

Use **Reject Candidate Submission** where the candidate can correct and resubmit the timesheet themselves.

Convert to Manual only when CloudTMS staff need to enter or process the replacement timesheet on the candidate's behalf.

Buttons: **Go Back** / **Use Reject Candidate Submission** / **Continue to Manual conversion**.

Issued paper pack not returned — QR_ISSUED_TO_MANUAL

A timesheet pack has already been issued

The candidate may already have printed the documents. Converting this timesheet to Manual will invalidate the current code and the issued pack can no longer be returned.

CloudTMS staff will become responsible for entering and processing the replacement timesheet. The issued pack will remain in the audit history.

Buttons: **Go Back** / **Continue to Manual conversion**. A mandatory intervention reason is shown before final confirmation.

Signed paper evidence returned — QR_SIGNED_TO_MANUAL

A signed timesheet has already been returned

Converting it to Manual will retire the signed returned evidence. The signed document will remain in the audit history but will not apply to the new Manual generation.

Continue only if the candidate or hiring manager has reported that the submitted hours are wrong, or another exceptional office intervention is required.

Buttons: **Go Back** / **Continue to Manual conversion**. A mandatory intervention reason is shown before final confirmation.

MANUAL to fresh ELECTRONIC — FRESH_ELECTRONIC_RESUBMISSION_REQUIRED

Switch this timesheet back to Electronic?

The current timesheet will be opened as a fresh electronic submission. Previous signatures and signed documents will remain in the audit history and will not be reused for changed content.

The worker will be notified that the timesheet must be reviewed and resubmitted.

Buttons: **Go Back** / **Switch to Electronic and notify worker**.

Worker notification title: **Your timesheet needs to be resubmitted**. Body: [Open the app to review and submit your timesheet again](#). Deep-link to the new current timesheet/workflow.

MANUAL to fresh paper submission — FRESH_PAPER_RESUBMISSION_REQUIRED

Create new signing documents?

A new timesheet pack and a new code will be created for the current hours. Any older pack or code will remain historical and cannot be returned.

The worker will be notified that new documents are ready and the timesheet must be resubmitted.

Buttons: **Go Back** / **Create new documents and notify worker**.

Worker notification title: **Your timesheet needs to be resubmitted**. Body after durable pack readiness: [New documents are ready for signing](#). [Open the app to continue](#).

QR replacement/reissue — QR_REPLACEMENT_PACK_REQUIRED

Issue a replacement timesheet pack?

The current pack and code will be invalidated. Any printed copy can no longer be returned. A replacement pack with a new code will be generated.

Please remember to tell the worker to sign the replacement timesheet before returning it.

Buttons: **Go Back** / **Issue replacement pack**.

Candidate email: [Please remember to sign the replacement timesheet before returning it](#). Recommended push after readiness: **Replacement documents are ready** / [Please sign and return the replacement timesheet](#).

Internal exact ELECTRONIC undo — EXACT_ELECTRONIC_RESTORE_PROVEN

This action is not shown in ordinary route actions.

Restore the previous electronic approval?

CloudTMS has proved that the current hours, signatures, signed document and financial content are identical to the previous electronic submission. Restoring it will make that exact approved electronic generation current again.

No worker resubmission will be requested.

Buttons: **Go Back** / **Restore exact electronic version**. If exact proof fails, use the fresh ELECTRONIC route.

24. Decisions still to be approved

The following were not found as final approved decisions in this task history or its supplied documents:

Candidate App visual design

The functional screen hierarchy, journeys, labels and required controls are agreed. A pixel-level visual design is not. Brand assets, final colour palette, typography, iconography, spacing, card appearance, motion and final iPhone/Android/web responsive mock-ups still require approval before the app frontend is treated as visually frozen.

Cross-platform implementation technology

No cross-platform implementation technology has been explicitly approved. That choice must be presented for approval after the backend/frontend contract audit and must not be recorded as settled policy beforehand.

Push provider and application publishing

The push provider/token format, Apple Developer organisation, Google Play organisation, app identifiers, signing identities, store listings, privacy-policy URL, support contact, screenshots and final pilot/publishing dates remain delivery decisions. The notification rules and timing are already agreed; the provider and publishing details are not.

Final public domains and configuration

The final Candidate App/web URL, public manager-approval URL and LIVE broker configuration are not yet frozen. TEST/LIVE separation and fail-closed environment binding are already fixed.

Independent backend/API audit findings

The current living plan records the DB/RPC authority, CloudTMS Candidate backend, private Candidate API and separate public broker foundation as implemented and deployed to TEST with all Candidate flags disabled. Independent final API-freeze verification remains the next gate. Any new verified finding may require implementation remediation, but it does not become a product-policy change unless the user explicitly approves changed behaviour.

25. Omissions and limitations

This audit used the complete recoverable history of this Codex task, the original engineering pack, the original Final Presentation Decisions Word document, later pasted independent audits/addenda, the 10 August suggested inclusion pack, the current installed SQL/repeatables, current Candidate backend documents and the current route-warning catalogue.

Superseded decisions are intentionally omitted, as requested. Only the current replacement rule is stated in the decision sections above.

Two earlier interpretations remain expressly superseded: WEEKLY Additional Units do not use a planned percentage-deviation comparison, and CloudTMS does not automatically interpret/reconcile handwritten Mileage Claim Form journey rows. Their current replacement rules appear in sections 6 and 9.

Raw SQL bodies, backend source code and detailed function inventories are not reproduced in this decision document because they are implementation evidence rather than product decisions. They remain in the backend repository and living implementation plan.

The audit cannot include decisions made outside this task and not supplied in an attachment, or private discussions that were never recorded here. No such omitted decision is known, but their absence cannot be proven from this task alone.

The original Final Presentation Decisions Word document was extracted structurally, rendered through Microsoft Word and visually checked across all four source pages before its current decisions were reconciled here.

26. Source precedence used for this audit

Where sources conflicted, the latest explicit approved instruction governed. The reconciliation order was:

1. later explicit user decisions and controlling addenda in this task, including the approved 10 August inclusion review;
2. later independent audit findings that the user explicitly accepted and instructed to implement;
3. the current approved W01–W13 route-warning catalogue;
4. the current living implementation plan, backend API contract and authority map;
5. the Final Presentation Decisions addendum;
6. Controlling Policy v7.0 and Full UI/App Flow Specification v3.0 for matters not later changed;
7. implementation-plan details only where they did not create new product behaviour.

Current code and database truth were used to confirm implementation status and authority shape. Code did not silently override an explicit product decision.

27. Office switch to Manual

Incomplete expense claim confirmation

This rule applies when CloudTMS office staff switch an ELECTRONIC or QR/PAPER timesheet to MANUAL and the candidate has one separate expense claim that has started but is not complete. The office must not be permanently blocked, and the claim must not be left active against a timesheet version that is about to become historical.

Mandatory office warning

The candidate has started an expense claim but has not completed it. Do you want to remove the incomplete claim and continue?

If the office selects No

Nothing changes. CloudTMS keeps the existing timesheet route and the incomplete expense claim exactly as they are. No workflow, approval request, email, notification, QR identity, evidence or timesheet version may be changed.

If the office selects Yes

CloudTMS must revalidate and lock the preview context, then complete one atomic transaction: retire any obsolete unsent PAPER delivery and readiness notification; invalidate the obsolete QR identity where applicable; cancel or supersede a live manager request and queue the established manager-cancellation message where required; supersede the incomplete expense workflow and its mutable lineage; and only then create the new current MANUAL timesheet version. Sent mail, signed documents, R2 objects and other immutable audit history remain retained.

REFUSED and safety boundaries

REFUSED remains a recoverable state because AMEND is available. It therefore receives the same warning. Yes supersedes that amendable lifecycle but retains the refusal reason, refusal timestamp and audit history; No leaves it available to amend. More than one affected workflow, an ambiguous identity, an unrelated claim, protected financial history or a live provider handoff must still fail closed. A temporary provider-handoff conflict may be retried; it must not silently discard the claim.

Presentation and future implementation

The office frontend must use the established professional CloudTMS confirmation-modal family, with clear Yes and No actions. Native browser or Windows alerts are not permitted. The modal must remain uncluttered and must be browser-tested with realistic populated data. Before frontend work, the DB/RPC/backend contract and regression matrix must independently prove No as zero mutation, Yes as complete atomic removal-plus-conversion, REFUSED history retention, provider fencing, and zero stranded active expense claims. This decision is mandatory input to the detailed office-frontend plan and, later, the Candidate broker, responsive-web, iOS and Android plans.

28. Exact replay and PAPER execution authority

Caller-owned semantic request identity

Every factual Candidate mutation requires the caller's bounded idempotency key. The backend must reject a missing key and must not substitute a random UUID. The durable receipt binds workflow, action, expected generation, caller/channel and factual inputs. Exact reuse returns the first durable result; another action or materially different payload returns

CANDIDATE_IDEMPOTENCY_CONFLICT.

WORKER_SUBMIT builds its semantic request and probes the receipt before rebuilding mutable workflow, financial or presentation material. The Candidate's signing time and factual claim/signature identity are included. Regenerated official presentation is excluded. Manager replay similarly excludes generated email, token and delivery values while reminder and renewal remain bound to the exact approval-request ID and generation.

Canonical finalisation completion

WEEKLY, PHONE, PAPER and DAILY completion is bound to the original workflow generation and one immutable approval identity, not to whichever valid trigger key first completes the work. EMAIL/PHONE binds approval request ID, request generation, method and immutable review digest. PAPER binds the exact returned manifest.

If PAPER_RETURN key K reaches RECEIVED but its immediate finalisation is blocked, a later retry key R may complete finalisation. Replaying K must then return the same committed **FINALISED** result. Mutable workflow generation/state, row signature and regenerated DAILY materialisation are considered only when no completion exists. A different approval or manifest cannot inherit another approval's result.

Exact manager-request ownership

Reminder and renewal use the request identity in the server action envelope. A newer request cannot silently replace the request the user acted upon. Generated mail/token material does not change semantic replay identity.

Canonical office rejection

The rejection authority locks actor plus key and binds environment, target, expected current identity, expected row signature and trimmed reason. Exact retry returns the durable result. Another target, signature or reason under that key fails before timesheet, workflow, notification, QR or mail mutation.

28. Exact replay and PAPER execution authority

Shared PAPER preparation states

- **PREPARING** - source document or pack work is still incomplete; pack retry is unavailable.
- **BACKOFF** - a retryable assembly failure exists but the next attempt is not due.
- **FAILED_RETRYABLE** - a closed transient assembly code, durable attempt count and due retry time exist.
- **FAILED_TERMINAL** - scheduler and Office execution stop; unsent mail remains inert and evidence is retained.
- **READY** - the exact complete-pack receipt is installed and normal provider fencing may continue.
- **RETIRED / STALE** - no preparation or retry authority remains.

Source-document readiness and failure ownership

The 15-minute preparation deadline detects stalled work but does not make an upstream source document retryable. A missing or non-ready source document remains **PREPARING**, including after the deadline, because pack retry cannot make that document ready. Only after the exact source document is **READY** can a transient pack-assembly failure become **FAILED_RETRYABLE**. A terminal source-document failure remains terminal.

One executor, backoff and crash recovery

Every actual pack attempt has a unique inner attempt identity and acquires the exact database lease for one workflow, delivery generation and manifest. Only a newly acquired claim may perform R2 reads or assembly. Replaying an earlier CLAIMED receipt is observational and must return **claim_acquired_new=false**. Only the matching operation ID and token can release the pack or record failure.

Retryable assembly failures use bounded backoff of 1, 5, 15 and then 30 minutes. Office must not bypass **next_retry_at_utc**. If an executor crashes after claiming, another attempt remains blocked while the ten-minute lease is active and may acquire a fresh attempt only after expiry. Attempt count advances only for an actual newly claimed execution.

Office retry outcome and preserved decisions

The Office retry UUID remains the durable outer operation. A concurrent exact call may return transient **RETRY_IN_PROGRESS**, but that response is not frozen as final. Completion stores the full **READY**, **FAILED_RETRYABLE** or **FAILED_TERMINAL** result and HTTP status; every later exact retry receives that result. No response exposes R2 storage identity.

Current/History, the incomplete-expense Yes/No warning, recoverable **REFUSED** rule, finalised history, provider fencing and the seven-table/fourteen-public-RPC boundary remain unchanged. No **DAILY/WEEKLY** economics, pay, charge, VAT, ERNI, margin, TSFIN, invoice, payment, Banking Pay, Policy X, settlement, remittance or production authority changes.

29. Authentication and operation-replay closure

Caller-owned mutation identity

Every factual Candidate authentication, account and session mutation requires one caller-owned bounded **idempotency_key**. The backend never substitutes a random operation key. The mandatory set is:

- challenge start, resend and verify;
- password activation/reset completion, login (including failed-login lockout mutation), refresh and logout;
- TEST candidate selection, notification preferences, notification read acknowledgement, push-token registration and password change.

The Candidate OpenAPI requires the key on every listed request. Same key plus the same factual request returns the same durable result. The same key with a different action, email/purpose, token identity or payload fails with **CANDIDATE_IDEMPOTENCY_CONFLICT**.

Secrets and lost-response recovery

Passwords, raw refresh tokens, raw challenge tokens and push-token ciphertext are not stored in ordinary audit receipts. Generated refresh, challenge and phone handoff material uses retained versioned key authority so an exact replay remains usable across an approved key rotation.

If refresh succeeds but its response is lost, repeating the old session/token with the original key returns the same successor session and refresh token without revoking the token family. Reusing that rotated token with a different key remains a security event. A failed login may advance the lockout counter once; its exact replay returns the same rejection and cannot increment the counter again.

Finalisation and phone replay

Finalisation performs a key-only durable receipt lookup before reading current approval state. A committed WEEKLY EMAIL/PHONE, PAPER or DAILY result therefore replays after its approval request becomes historical or superseded, without duplicate financial placement, final documents or notifications. Phone semantic identity excludes generated token/hash/expiry facts and an exact replay returns the originally usable token under its recorded key version.

PAPER observation, execution and Office crash recovery

A missing or non-ready source document remains **PREPARING**, non-retryable and attempt-count zero, including after its observation deadline. Only a READY source may acquire the exact pack attempt. Genuine render, source-read, R2 or assembly failures after that claim use the closed retryable/terminal catalogue and bounded backoff.

For Office PAPER retry, the canonical inner READY or failure transition and the outer Office UUID result are written in one database transaction. The database can reconstruct a missing legacy outer receipt from the exact inner operation state after a Worker crash; every later exact call replays that result. No response exposes an R2 storage key.

Preserved boundaries

Current/History, route/rejection, resubmission, manager-mail, immutable evidence, provider permits and the seven-table/fourteen-public-RPC boundary remain unchanged. No DAILY/WEEKLY economics, pay, charge, VAT, ERNI, margin, TSFIN, invoice, payment, Banking Pay, Policy X, settlement, remittance or production authority changes.

30. Public credential replay and push-token identity

One stable public authentication result

A successful login, password activation/reset or refresh has one public result. The public Candidate session ID is a stable opaque identifier derived from the environment and immutable private session identity. Repeating the same factual request with the same operation key returns the same public session ID, access token, refresh token and frozen expiry facts; the broker must not generate a fresh public UUID or wall-clock timestamp on replay.

Deterministic authenticated public envelopes

New public access, refresh and PHONE handoff credentials use the reviewed **v2** deterministic authenticated envelope. Canonical plaintext receives a purpose-separated HMAC identity and its own HMAC-derived AES-GCM key. Distinct canonical plaintext therefore does not reuse one key/nonce pair; an exact replay intentionally reproduces the identical authenticated string. Existing valid random-IV **v1** envelopes remain readable during rollout.

Public access/refresh claims use the private database receipt's issued, session-expiry and absolute-expiry facts. Selected-candidate access uses the initiating access credential's frozen issue time. PHONE handoff uses the approval request's frozen creation and expiry times. Changed purpose, payload, device or session binding must fail validation.

Concurrent database winner

For activation/reset, login and refresh, two simultaneous exact requests may propose different private session IDs. After the database returns the durable winner, each handler derives the returned refresh token from the **result.session_id**, recorded token-key version, action and caller operation key. A losing provisional token is never returned beside the winning session.

Push-token storage versus factual identity

The raw push token remains broker-only and is encrypted for storage with a fresh random AES-GCM IV. Random storage ciphertext is not factual idempotency identity. The broker separately supplies a stable, purpose-separated HMAC over:

- environment and provider;
- public Candidate session identity;
- the exact raw push token.

The private request receipt hashes that semantic identity and key versions, not randomized ciphertext. Same raw token/provider/session plus the same operation key replays one success; a changed token, provider or session under that key conflicts. Neither the raw token nor its randomized ciphertext is written into ordinary audit receipts.

Concurrent mutable-precondition recovery

If an exact simultaneous logout reaches an already-revoked session, or an exact simultaneous password change reaches the newly written password verifier, the private API performs one second exact receipt lookup. Matching receipt returns the first durable result; a different factual request conflicts; absence of a receipt preserves the original authentication failure.

Preserved product and authority boundaries

The Current/History split, 16-week History limit, week-ending ordering and labels, row-tap detail/action hub, incomplete-claim warning before MANUAL conversion, Office actions, route/rejection rules, seven Candidate tables and fourteen public Candidate RPCs remain unchanged. No frontend implementation, DAILY/WEEKLY economics, pay, charge, VAT, ERNI, margin, TSFIN, invoice, payment, Banking Pay, Policy X, settlement, remittance or production authority changes.

31. Public authentication boundary, replay and key rollout

Closed public authentication routes

Unauthenticated Candidate authentication is a closed catalogue: challenge start/resend/verify, password completion, login and refresh only. Logout is authenticated. The broker must open the public access credential and forward the exact internal bearer to the private logout receipt owner. Missing or invalid public access returns 401 and cannot reach the mutation.

Challenge result truth

Challenge start and resend require one caller-owned bounded idempotency key. Missing, blank or oversized keys return 400. Same key plus changed email, purpose or challenge identity returns 409 CANDIDATE_IDEMPOTENCY_CONFLICT. Only Candidate eligibility and account-state outcomes are enumeration-masked to the generic 202 accepted response; outages and throttling remain visible as service/429 outcomes.

Versioned public credentials

New access, refresh and same-phone PHONE credentials use deterministic authenticated **v3** envelopes containing the issuing key version. Each credential authority has one current writer version and an explicit reader catalogue. Login, activation/reset and refresh freeze the chosen access, refresh and public-session mapping versions in the durable private result. Exact replay therefore reconstructs the byte-identical public result after a supported rotation. Refresh retains the initiating public-session mapping version. The broker proves all selected wrapping secrets before the private mutation starts.

Retained v1/v2 readers support controlled rollout. Removing a version from the reader catalogue makes that version unacceptable even if its secret remains bound. The approved rollback target is the separately published v3-compatible reader deployment, with former writer versions restored while every version issued by the newer deployment remains readable until its bounded credentials and receipts expire. A pre-v3 binary is not an approved rollback target.

PHONE and push semantic binding

PHONE selection binds the workflow/generation/key to the initiating public-session digest and, where supplied, device digest before any handoff token is generated. Exact replay returns the same usable private and public handoff using the recorded key versions; another workflow/session or changed supplied device conflicts.

Push storage and factual identity remain separate. Random-IV ciphertext embeds its positive database-safe storage-key version. A versioned HMAC binds environment, provider, public session and raw token. During approved identity-key overlap the broker supplies proofs for configured reader versions and the private durable receipt reselects its frozen semantic version. Storage drift or supported key rotation replays; changed token/provider/session conflicts.

Release verification and preserved boundaries

Before independent GO, each affected public mutation must prove:

- public broker -> signed private API -> RPC/database -> durable private result -> public response;
- exact and concurrent replay, changed-input conflict, generated-execution drift and crash recovery;
- supported writer rotation, reader retirement and approved rollback compatibility;
- one factual mutation and no duplicate communication/provider side effect.

The Current/History split, 16-week History window, row action hub, incomplete-claim MANUAL warning, Office modal behaviour, seven Candidate tables and fourteen public Candidate RPCs remain unchanged. Candidate and Office frontend wiring remains blocked until independent API GO. No DAILY/WEEKLY economics, rates, pay, charge, VAT, ERNI, margin, TFSIN, invoice, payment, Banking Pay, Policy X, settlement, remittance, production or future Office-role policy is changed.

32. Final public-authentication throttle and key authority

Resend acceptance and durable throttling

A public challenge resend returns **202 accepted** only when the database has durably accepted the operation. A resend attempted too soon returns a visible 429 response with server-owned retry timing. A resend that has exhausted the permitted allowance returns a stable terminal 429 response. Neither condition is enumeration-masked as successful acceptance.

A throttle result consumes the supplied idempotency key and is recorded as the durable result. The same key and same factual request always replays that result, even after time advances. A later permitted resend must use a new caller-owned key. Same key plus changed challenge identity, email or purpose remains an explicit `CANDIDATE_IDEMPOTENCY_CONFLICT`.

Challenge-token issuing version and rollback

Every accepted challenge start or resend freezes the exact challenge-token key version in its durable receipt. Challenge-token authority has one current writer version and an explicit retained-reader catalogue. Exact replay uses the recorded issuing version directly; it does not infer the version by scanning only up to the current writer.

The supported rotation contract is:

- writer 1 -> writer 2: retained version-1 receipts remain readable while reader 1 is present;
- approved writer 2 -> writer 1 rollback: version-2 receipts remain readable while reader 2 is present;
- reader retirement: a receipt using the removed version fails with a stable unavailable result.

Public credential version integrity

New public access, refresh, public-session and PHONE credentials use deterministic authenticated **v4** envelopes. The issuing key version is cryptographically included in the identity HMAC, per-message AES-GCM key derivation and authenticated data. Changing only the textual version label therefore invalidates the credential, including where two version slots were accidentally assigned the same secret material.

Bounded readers for v1, v2 and v3 remain available for controlled compatibility. The broker rejects a credential-authority configuration where distinct version slots resolve to identical secret material; this also prevents retained legacy v3 credentials from being relabelled across aliased slots. Removing a version from its reader catalogue makes credentials issued by that version unacceptable.

Unknown-account login idempotency

An unknown-account login receives the same durable, enumeration-safe generic failure receipt as other login outcomes. No Candidate account is created and no account failure counter is changed. Same key plus the same factual login replays the durable failure; changed email or password under that key returns an idempotency conflict.

Cutover and preserved boundaries

The v4 writer cutover is approved only under the verified dormant state: all Candidate client flags false, all seven Candidate business tables empty and Candidate-bound mail empty. Production remains untouched. Any future environment containing retained v3 credentials or receipts must keep the compatible readers and prove its bounded transition before changing its writer.

This decision adds no Candidate business table and no public Candidate RPC. It does not change Current/History, Office row actions or modals, Candidate workflow economics, DAILY/WEEKLY calculations, rates, pay, charge, VAT, ERNI, margin, TSFIN, invoices, payments, Banking Pay, Policy X, settlement, remittances, production or future Office role policy. Candidate and Office frontend API wiring remains subject to independent backend/API GO.

33. Mixed-version concurrency ownership

Database winner owns challenge delivery

During an approved rolling private-Worker deployment, two instances may propose different challenge-token writer versions for the same factual START or RESEND. The local token is only a proposal. Every successful or replayed canonical result returns the database-frozen token hash and issuing version to the private service. After that RPC returns, only those winner facts may control delivery.

Each handler reconstructs the token from the exact retained winner version, verifies its SHA-256 hash and then attempts the deterministic create-only mail identity. A losing Worker must never queue its local token, even if its mail write arrives first. Exact replay may repair a database-committed/mailer-missing crash, but the repaired mail must contain the database winner's token.

Authentication request version is frozen before hashing

For every authentication/account operation, the first caller reserves one request-HMAC key version under the existing environment and idempotency-key database lock before any password proof, refresh-token proof or factual request hash is calculated. A concurrent Worker proposing another current writer receives and uses the already frozen version.

The reservation applies to:

- activation/password completion, login success and generic login failure, and refresh;
- logout, TEST Candidate selection and notification preference/read mutations;
- push-token registration and password change.

The reservation and completed durable response are one receipt lifecycle in the existing audit authority. It stores no raw password, refresh token, challenge token or push token. Same key plus another action or a main request that attempts to replace the frozen version returns CANDIDATE_IDEMPOTENCY_CONFLICT.

Rotation, rollback and retirement

The current writer version is automatically readable. Additional retained readers are explicit. An in-flight operation continues using its frozen version across writer rotation or approved rollback while that reader remains configured. Deliberate reader retirement fails closed with a stable unavailable result before mutable preconditions or business mutation.

Mandatory release proof

Verification must combine concurrency and rotation rather than test them separately: START and RESEND with writer versions 1/2, either database winner and either mail arrival order; identical login success/failure, activation and refresh requests across request-HMAC writers; representative authenticated account actions; changed factual input/action; rollback; and reader retirement. PostgreSQL 17.6 and 18.1 and a real private-handler/database chain are required.

Preserved boundaries

This decision adds no Candidate business table and no public Candidate RPC. It does not change public Candidate routes, Office modal behaviour, Current/History, workflow or PAPER policy, DAILY/WEEKLY financial calculation, rates, pay, charge, VAT, ERNI, margin, TSFIN, invoices, payments, Banking Pay, Policy X, settlement, remittances, production or future Office role policy. Candidate flags remain false and frontend API wiring remains subject to independent GO.

34. Credential winner and security receipt

Database winner owns PHONE handoff material

During an approved rolling private-Worker deployment, two instances may propose different manager-token writer versions for the same factual SELECT_PHONE_APPROVAL operation. A locally generated token is only a proposal. The canonical workflow result freezes and returns an internal approval-token hash and the winning handoff-token key version. Those database facts are authoritative after the RPC returns.

Every successful or replayed private handler reconstructs the deterministic token from the workflow ID, pre-action generation, caller operation key and returned winner version; verifies its SHA-256 against the returned winner hash; discards any local proposal; and removes the internal hash before returning. A losing Worker and the public broker therefore receive the same usable winner token.

Refresh-token reuse is an atomic security operation

Reuse of a rotated predecessor refresh token revokes every ACTIVE or ROTATED session in its token family and returns CANDIDATE_REFRESH_TOKEN_REUSE with family_revoked true. Family revocation and that negative response must complete the same durable authentication receipt in the same database transaction.

An exact or concurrent retry using the same factual request and security-event key returns the stored negative security result. It must not re-evaluate the predecessor after it has become REVOKED, substitute CANDIDATE_SESSION_EXPIRED, derive a successor credential or repeat a family mutation. A different key remains a separately evaluated security event under the established theft-protection contract.

Mandatory release proof

Verification must include:

- PHONE first execution through two real private handlers on manager-token writers 1 and 2;
- both possible database winners and both returned private/public token-validity checks;
- refresh success, rotated-predecessor reuse, deliberately lost security response and exact retry;
- simultaneous exact refresh-reuse security requests with one family revocation and one durable result;
- PostgreSQL 17.6 and 18.1, the complete backend suite and all three Worker builds.

Preserved authorities

Challenge database-winner delivery, authentication request-HMAC version reservation, public v4 credential binding, unknown-account failure receipts, public session/access/refresh replay, PHONE public-session/device binding, push semantic identity, Current/History, resubmission, manager mail, PAPER and Office retry remain unchanged. Internal winner hashes are service-only and never public response data.

No-change boundary

This decision adds no Candidate business table, public Candidate RPC or financial authority. It does not change DAILY/WEEKLY financial calculation, rates, pay, charge, VAT, ERNI, margin, TFSIN, invoices, payments, Banking Pay, Policy X, settlement, remittances, production, Office modal functionality or future Office role policy. Candidate flags remain false and frontend API wiring remains subject to independent GO.

35. Account-session invalidation concurrency

One bounded session-lifecycle concurrency owner

Every Candidate session create, rotate or family/account-wide invalidation for one account uses `private._candidate_auth_account_session_lock_v1`. The lock is transaction scoped, keyed by environment and account ID, and unavailable to public, anon, authenticated and service roles. It creates no Candidate business table and no public Candidate RPC.

Mandatory lock order and revalidation

The stable order is authentication receipt/idempotency-key ownership, account-session advisory lock, account row lock, session row locks, mutation and durable result receipt. If only a session is initially known, its account ID is read as identity only; account and session state, environment, status, refresh proof, expiry and family are re-read after the shared lock is held.

Participating operations and closed postconditions

- Normal refresh and rotated-token reuse share the same per-account lock. `family_revoked=true` requires zero ACTIVE or ROTATED rows in that token family.
- Existing-account activation/password reset leaves only the new reset session ACTIVE.
- Password change leaves only the initiating policy-retained session ACTIVE.
- `REVOKE_SESSIONS`, `LOCK` and `DISABLE` leave zero ACTIVE sessions.
- `LOGIN_SUCCESS` session creation and five-session cap enforcement use the same lock, so an account invalidation cannot be bypassed by a concurrent login.

Mandatory adversarial release proof

Disposable PostgreSQL tests must use real independent transactions and execute both operation orders for:

- rotated-predecessor reuse versus legitimate current-successor refresh;
- password change and verified password reset versus another-session refresh;
- `REVOKE_SESSIONS`, `LOCK` and `DISABLE` versus refresh;
- `LOGIN_SUCCESS` versus `DISABLE`.

PostgreSQL 17.6 and 18.1 must both prove the exact permitted final session set, no escaped successor, no partial mutation and no deadlock. Existing PHONE winner, durable refresh security receipt, challenge/key rotation, Current/History, resubmission, provider permit, PAPER and Office regression authorities remain green.

No-change boundary

This decision does not change Candidate workflow, Office modal functionality, frontend role policy, financial calculations, invoices, payments, Banking Pay, Policy X, settlement, remittances or production. Candidate feature flags remain false and frontend API wiring remains subject to independent GO.

36. Locked password-authority revalidation

Worker verification is preflight, not mutation authority

The private Candidate Worker may load a password verifier and perform PBKDF2 work before the database call, but that mutable REST snapshot never authorises login session creation, failed-login accounting or password replacement. The canonical database transition revalidates the exact authority after its transaction locks.

Non-plaintext proof and locked comparison

- For a known account, the Worker sends a derived presented-password digest and a SHA-256 fingerprint of the exact verifier authority it inspected: account, scheme/version, salt, digest and canonical parameters.
- No plaintext current or new password enters PostgreSQL or an ordinary durable receipt.
- After receipt ownership, the shared account-session advisory lock and account-row FOR UPDATE, PostgreSQL recomputes the fingerprint and compares the presented digest with the locked current digest.

Closed concurrent outcomes

- A stale positive login cannot create a session after password reset or change.
- A stale negative login cannot increment the failed-login counter after the verifier changes; only a genuine mismatch against the current locked verifier may increment once.
- Of two concurrently preverified password changes, only the proof matching the current locked verifier may commit. The other returns the durable generic invalid result and cannot overwrite the winner or revoke sessions.
- Exact same-key successful replay continues to return the durable winner after the verifier has moved; changed factual input still conflicts.

Mandatory adversarial release proof

The real private-handler/PostgreSQL chain must run reset/login and change/login in both commit orders, stale failed login versus reset, and two password changes whose Workers both preverify the old password before either database mutation. PostgreSQL 17.6 and 18.1 must prove no stale session, wrong counter change, verifier overwrite, deadlock or partial mutation.

No-change boundary

This decision adds one private helper only. It adds no Candidate business table or public Candidate RPC and does not change Candidate workflow, Office modal functionality, frontend role policy, finance, invoices, payments, Banking Pay, Policy X, settlement, remittances or production. Candidate feature flags remain false and frontend API wiring remains subject to independent GO.

37. Office Candidate frontend implementation

API-freeze gate status

The independent Candidate DB/RPC/backend/API and integrated Office Candidate API review issued GO on 13 August 2026. Earlier page statements that Office frontend wiring remained blocked until independent API GO record a gate that has now been satisfied; they are not current blockers. The Office Candidate frontend may therefore be implemented and deployed to TEST against the frozen contract. Candidate responsive web, iOS and Android implementation remains separate future work.

Authority, compatibility and presentation ownership

The normal authenticated CloudTMS Office remains the sole Office surface. Candidate sessions never receive Office authority. The frontend consumes the frozen server projection and typed action envelopes and does not infer lifecycle eligibility, row identity, financial protection, reminder timing, QR ownership or idempotency rules. The existing Office authentication and authorisation boundary is preserved and Candidate App user authority is unchanged.

Office staff do not perform manager approvals or refusals. A manager decision remains manager-owned. Office displays the resulting status and evidence only. EMAIL and PHONE are implementation methods and are never shown to the Office user as status labels, badges, method fields or Office decision controls.

Approved Office status catalogue

Only the following Candidate Submission labels may be rendered. A new label requires explicit product approval before implementation:

- Awaiting Candidate Submission
- Candidate Submitted
- Awaiting Manager Approval
- Manager Approved
- QR Awaiting Signed Return
- QR Pack Preparing
- Finalising Submission
- Finalisation Needs Attention
- QR Pack Needs Attention
- Refused by Client
- Rejected by Agency
- Candidate Submission Cancelled
- Candidate Submission Complete
- Status unavailable

Refused by Client means that the client/manager refused the submitted claim. Rejected by Agency means that authorised Office staff rejected the Candidate submission before Authorisation and the Candidate must follow the server-owned recovery/resubmission route.

Timesheet Summary

Timesheet Summary contains one dedicated, read-only Candidate Submission column immediately after Processing Status and before Issues. It is compact, uses at most two visible lines and participates fully in the existing Summary-grid preferences. The Office user can sort it by the approved display label, drag it to another position and resize it; the chosen order and width are persisted exactly like peer columns. Sorting applies to the complete filtered result before pagination. Resizing grows the table into the established horizontal-scroll region so columns to its right remain independently draggable and responsive. It contains no action buttons. Candidate state is never duplicated into Issues; Issues contains actual issues only. Unknown or unavailable Candidate authority fails closed as Status unavailable.

One winning Candidate and QR status

Summary, Simple Timesheet, Bulk Process and Bulk Authorise use one shared presenter and render only the single approved status furthest along the authoritative lifecycle. QR Pack Preparing is replaced by QR Awaiting Signed Return once the pack is ready/issued. Once signed return evidence is received, neither earlier QR badge remains: Finalising Submission is current until later Candidate Submission Complete or terminal Candidate truth wins. Mutually exclusive QR progress badges are never stacked or shown simultaneously.

37. Office Candidate frontend implementation

Simple Timesheet modal

The established Overview, Lines, Expenses, Evidence, Issues, Finance and Audit tabs and the existing modal family are preserved. Candidate Submission status is placed in the existing Overview stage/workflow area. Candidate actions are inserted only when the canonical projection returns that exact action as enabled for the exact current row. Existing Authorise, Unauthorise, Process, finance, invoice and payment controls remain unchanged.

Evidence and QR terminology

The Office interface uses QR Pack for the complete pack and QR Timesheet when referring only to the timesheet. It does not use PAPER as user-facing terminology. The combined issued pack is shown in Evidence as Unsigned QR Pack and is retained for audit only; it is not authorisable evidence. Returned signed documents are displayed separately and classified by their server-owned document type, including Timesheet and the established expense evidence classifications such as accommodation. Evidence retains the existing View and Download controls and every existing column; narrow layouts use an internal horizontal scroll rather than removing information.

QR Pack Preparing means CloudTMS is assembling the official pack in the background and no Office retry is yet available. Retry QR Pack Preparation appears only for an explicit server-owned retryable failure. QR Awaiting Signed Return means that the issued pack exists but the official signed documents have not yet been returned, so the timesheet is not eligible for Authorisation.

Simple Timesheet action catalogue

The following Candidate actions may appear only where the server says that exact action is eligible:

- Send Manager Reminder - only for a live manager request that is currently eligible for another reminder.
- Request Manager Approval Again - only for an expired, otherwise unchanged manager request.
- Reject Candidate Submission - only before Authorisation and outside protected financial states; never on an authorised timesheet.
- Retry Finalisation - retries only the failed technical finalisation and does not repeat or replace a valid manager decision or signature.
- Retry QR Pack Preparation - only for an explicit server-owned retryable failure.
- Create Replacement QR Pack and Notify Worker - invalidates the old pack/code and creates a replacement; Simple Timesheet only.
- Convert to Manual - only through the approved preview, warning and revalidation flow.
- Enable Electronic Submission - only where a manual record is eligible for electronic submission.
- Enable QR submission - only where a manual record is not eligible for electronic submission but is eligible for QR submission.

Enable QR submission is never shown where electronic submission is eligible, because the Candidate chooses QR or electronic submission in that case. Resend QR Pack is present only as a disabled Simple Timesheet placeholder until the backend gains a separately approved resend authority. Cancel Manager Approval Request is not shown anywhere in the Office frontend.

37. Office Candidate frontend implementation

Bulk Process and Bulk Authorise

Bulk Process may expose only: Send Manager Reminder; Request Manager Approval Again; Reject Candidate Submission; Retry Finalisation; Retry QR Pack Preparation; Convert to Manual; Enable Electronic Submission; and Enable QR submission. Each action remains row-specific and appears only when the server marks it eligible. Replacement and resend QR Pack actions are not available in Bulk Process.

Bulk Authorise may expose only Reject Candidate Submission as a Candidate action, and it is absent for authorised rows. Replacement and resend QR Pack actions are not available in Bulk Authorise. Existing Bulk Process and Bulk Authorise financial, processing and authorisation controls retain their existing authority and behaviour.

Send Manager Reminders workspace

The Timesheet tools sidebar contains Send Manager Reminders immediately below Bulk Process. It opens a dedicated professional modal showing only reminder-eligible manager requests across the server-owned Office reminder catalogue; the current Timesheet page filters do not narrow this eligibility set.

- Columns are selection, Candidate and Last request or reminder sent. Candidate and last-sent headers sort their complete result; the selection header remains the all-pages select/clear control rather than a competing sort control.
- A live surname search filters as the user types. Clearing or changing the search does not clear selections, so several candidates can be selected across successive searches.
- Pagination uses Previous, Next and Page n of n. The header checkbox selects or clears all eligible rows across every page, not only the visible page.
- The catalogue fails closed rather than partially displaying or sending when more than 1,000 requests are actually eligible.
- Send Reminders and Cancel are the only workspace actions. Send Reminders opens a styled CloudTMS confirmation describing the exact selected count before any mutation.
- The result view reports Sent, no longer eligible and Failed outcomes and has a Close action. Eligibility is revalidated by the server at execution time.

Confirmations, conflicts and responsive quality

Every Candidate mutation uses the established styled CloudTMS confirmation family with clear plain-English consequences and never a native browser or Windows alert, confirm or prompt. No permanent Refresh button is added. Refresh current state appears only inside a controlled stale/conflict message. The UI must remain keyboard accessible, responsive and professionally laid out; desktop and narrow Playwright tests must prove the patched assets, modal behaviour, action gating, method hiding, status wording and absence of native dialogs.

Durable manager-reminder result and lost-response recovery

An accepted reminder batch always returns top-level ok=true because a durable result exists even when individual items are PARTIAL or FAILED. Per-item success, no-longer-eligible and failure counts remain authoritative inside that durable result. A top-level false response means no durable batch result. If the execute response is lost or uncertain, the browser first reads the exact batch identity. Only an authoritative not-found permits one exact retry with the same batch ID, frozen selection and idempotency key; no second batch or key is invented. Continued uncertainty preserves that identity and exposes only the controlled Refresh current state recovery.

Preserved app-ready and no-change boundaries

The Office implementation is prepared for the future Candidate App by consuming the same canonical status, evidence, action and identity contracts. It does not add Candidate authority or change Candidate App users. It adds no Candidate business table or public Candidate RPC and changes no DAILY/WEEKLY calculation, rate, pay, charge, VAT, ERNI, margin, TSFIN, invoice, payment, Banking Pay, Policy X, settlement, remittance or production authority. Frontend wiring remains subject to the verified TEST rollout and independent re-audit gate.

38. Manager reminder continued-uncertainty ownership

Controlling outcome

The manager-reminder workspace owns at most one unresolved batch for the current authenticated Office session. A lost or uncertain HTTP response never authorises a replacement batch, a replacement idempotency key, a changed selection or another confirmation. The original frozen batch remains the only operation until CloudTMS obtains an authoritative result or an authoritative rejection proves that the operation was not accepted.

Frozen operation identity

The retained recovery receipt freezes all facts needed for exact recovery:

- batch ID and identical idempotency key;
- selection mode, selected row identities and selection fingerprint;
- catalogue revision and exact preview facts;
- operation phase and whether the single permitted exact retry has been consumed;
- the authenticated Office user that owns the unresolved operation.

Recovery-only presentation

After continued uncertainty, the ordinary reminder catalogue is replaced by one professional recovery-only view. It displays the retained batch facts and exposes only Refresh current state. Surname search, row selection, Select All, sorting, paging, Send Reminders, Cancel and the modal Close control are unavailable. A function-level guard also blocks send execution before UUID generation, preview or confirmation whenever an unresolved batch exists.

One exact retry, then status-only

After an uncertain execute response, CloudTMS reads the exact batch status first. The first authoritative CANDIDATE_REMINDER_BATCH_NOT_FOUND response permits one exact POST retry using the unchanged frozen request. Retry consumption is persisted before that POST begins. If uncertainty continues, every Refresh current state action is GET-only; no further execute POST and no new operation identity may be produced.

Modal and Office-session lifecycle

The unresolved receipt is owned outside disposable modal state and survives forced dismissal, reopening and page refresh within the same authenticated Office session. Reopening restores the exact recovery-only view instead of loading a fresh sendable catalogue. The receipt is cleared when an authoritative durable result is rendered, when a stable non-uncertain rejection proves safe non-acceptance, or when the Office session is cleared or replaced. A different Office user cannot adopt the receipt.

Durable outcomes and preserved boundaries

COMPLETED, PARTIAL and FAILED remain durable structured results with authoritative item counts; PARTIAL or FAILED is not a transport uncertainty. Once any durable result is recovered, the protected state clears and a genuinely new batch may be started. This correction changes only the Candidate Office reminder workspace and its frontend cache identity. It changes no Candidate database definition, RPC, backend/API contract, Office action authority, Candidate public feature flag, Office role, financial calculation, invoice, payment, Banking Pay, Policy X, Worker or production resource.

Mandatory verification

Acceptance requires unit and real-browser proof of: execute uncertainty plus status uncertainty; authoritative 404 plus one exact retry and later status-only refreshes; blocked close, Escape and ordinary controls; exact restore after dismissal/reopen; eventual PARTIAL and FAILED recovery; no second UUID or confirmation; desktop and narrow professional layout; deployed-asset parity; and preservation of the complete Candidate Office status, QR-precedence and Timesheet Summary regression matrix.

Implementation authority: TEST-Frontend runtime commit 760477f45dd897e4d05d07af90d75b1fabcb0b2c; final evidence head 81a33e79a80e211ef91c0d8031d3244d8334645e. Candidate public features remain disabled.

39. Office runtime authority and closed-world reminder recovery

Closed-world authoritative reminder outcomes

After reminder execution may have reached the server, only two status-read outcomes may change the protected operation: an exact durable COMPLETED, PARTIAL or FAILED result resolves it; and the exact stable CANDIDATE_REMINDER_BATCH_NOT_FOUND result may permit the one frozen retry where that retry is still unused. Every other status-read failure is non-authoritative about whether the original batch was accepted.

The browser therefore retains the exact batch and recovery-only view after, without limitation:

- network loss, timeout, malformed or unavailable status truth and HTTP 5xx;
- HTTP 400, 401, 403, 409, 429 or any future non-404 error;
- permission, authentication and rate-limit failures affecting the status request itself.

Such errors never clear the receipt, re-enable the reminder catalogue or authorise a replacement UUID, key, selection or confirmation. A later exact not-found may consume the single retry; once consumed, all later Refresh current state actions remain GET-only.

Normal TEST Worker environment authority

The normal TEST backend Worker must define CANDIDATE_APP_ENVIRONMENT as TEST in its checked-in TEST Wrangler configuration. The Office Candidate service capability and projection routes use that binding to select the approved TEST environment. Missing or invalid authority fails closed and must not be mistaken for an ineligible timesheet.

Candidate public feature flags remain a separate client boundary. All 12 stay false while the authenticated Office service surface remains enabled for authorised Office users. This configuration does not enable Candidate login, reads, writes, notifications, manager flows or QR processing for Candidate users.

Deployment and browser acceptance

Every normal TEST Worker publication must prove:

- a repository regression test finds exactly one TEST binding with the exact value TEST;
- the Wrangler TEST dry build includes that binding and the normal TEST Worker deploy is healthy;
- the real authenticated capabilities endpoint returns the enabled Office contract rather than CANDIDATE_ENVIRONMENT_INVALID;
- real eligible Electronic rows display Awaiting Candidate Submission in Summary and Simple Timesheet, and applicable Bulk surfaces initialise;
- Candidate flags and Candidate business data remain disabled/empty throughout harmless verification.

Preserved boundaries and implementation authority

This closure changes no Candidate database definition, table, public RPC, Office adapter, OpenAPI, action policy, status catalogue, Candidate user authority, timesheet economics, finance, invoice, payment, Banking Pay, Policy X or production configuration. It changes only the normal TEST Worker environment binding, its regression test, the Candidate Office reminder error classification, its tests and frontend cache identity.

Implementation authority: frontend b06efa29966a28fbb9a5b548239b558d3ca6d71f; backend c0b5d86a1b2ba155f466cc1168a169964d9c8b9a; normal TEST Worker 4fc999ec-983c-4314-8303-e05929ec04ff. Candidate public features remain disabled.

40. Candidate applicability, Daily identity and immediate Summary truth

Candidate lifecycle applicability

Candidate submission status is displayed only for the canonical ELECTRONIC or QR route families. Manual non-QR, Manual adjustment, HealthRoster/NHSP import-authoritative and import-authoritative adjustment rows remain blank in Timesheet Summary, Simple Timesheet, Bulk Process and Bulk Authorise. A current Manual row may still expose an exact server-enabled route-conversion action; that does not manufacture Candidate lifecycle truth before conversion.

Durable completion proof

Authorised, Invoiced and Paid are Office financial facts, not proof that the Candidate used or completed the Candidate submission workflow. Candidate Submission Complete requires a durable Candidate workflow in FINALISED state. Historic financially protected ELECTRONIC/QR rows with no Candidate workflow remain blank. A current eligible unprocessed ELECTRONIC/QR row with no workflow may show Awaiting Candidate Submission.

Daily and Weekly exact identity

DAILY Candidate identity is owned by the exact current timesheet and its booking/version family. A DAILY projection must not require or manufacture a contract_weeks row. WEEKLY Candidate identity remains the exact current timesheet plus its single exact contract-week record. Mixed, ambiguous or moved identities continue to fail closed.

Immediate Timesheet Summary transport

When the authenticated Timesheet Summary requests Candidate truth, the normal backend composes the existing canonical Office PROJECT_BATCH projection into the same Summary response before returning the rows. Composition is partitioned into batches of no more than 100 exact identities. Duplicate display row keys are never collapsed; each exact identity is preserved in a separate valid batch where necessary.

- The browser validates embedded contract version, exact row identity and row signature before first-paint rendering and cache seeding.
- A row carrying the embedded-result marker never starts a second after-render Office projection request for its initial grid cell.
- Established Manual and import-authoritative routes are resolved as immediate blank values without canonical projection work; the exact row route outranks broad client/family hints.
- Real TEST measurement recorded 153 ms median with Candidate projection versus 133 ms without it: 20 ms added median cost and zero browser follow-up projection requests.
- Full Simple Timesheet detail, explicit refresh and mutation recovery continue to use the established Office routes.
- The Issues column remains sourced from issue_codes in the main Summary payload and does not become a Candidate after-render field.
- No Candidate table, public RPC, economic calculation, finance, invoice, payment, Banking Pay, Policy X or production authority changes.

Implementation authority

Frontend 7cab427272a7d21eb922c51765442548d0c3ab53; backend 869bd349644f16c02dec33c5076bdb536e39a56; normal TEST Worker b2f36fcc-6c11-4336-9dd2-5bc8ccd8df7c. Candidate public feature flags remain disabled.

41. Office route, processing and Candidate authority closure

One server-owned applicability decision on every Office surface

Manual non-QR, HealthRoster-authoritative, NHSP-authoritative and import-authoritative rows have no Candidate submission lifecycle. Summary, Simple Timesheet, Bulk Process and Bulk Authorise receive the same server-owned not-applicable marker, display a blank Candidate state and perform no Candidate projection request. A current eligible Electronic/QR row with no workflow may show Awaiting Candidate Submission; financial completion alone never proves Candidate completion. Candidate Submission Complete requires durable FINALISED workflow truth.

Route, Processing Status and Candidate Submission are separate

- Route displays canonical QR only for a QR/QR-only route, Manual only for Manual non-QR, and Electronic for an Electronic-capable route. A later Candidate QR Pack choice does not relabel an Electronic route.
- Processing Status is limited to Unprocessed, Processed, Authorised for Invoicing, Partially Invoiced, Invoiced, Archived and fail-safe Processing Delayed.
- Candidate and QR lifecycle wording appears only under Candidate Submission. Legacy Awaiting signed QR timesheet and legacy QR issue/projection gates do not control Processing Status or Office lifecycle actions.

Authorise and signed QR return authority

Office Authorise and Unauthorise consume only the canonical server action flags and TSFIN lifecycle authority. A QR row can reach PENDING_AUTH or READY_FOR_HR only after the canonical Candidate finaliser has accepted the complete signed return manifest and completed the established financial/Process composition. An issued unsigned QR Pack, partial return, QR code, retained legacy QR field or legacy waiting label never enables Authorise. A deliberate conversion to Manual removes Candidate/QR gating and follows the unchanged Manual rules. Import-authoritative rules remain unchanged.

Timesheet Summary transport and column behaviour

- Candidate projection truth is embedded in the initial authenticated Summary response and paints with the normal row; the browser does not fan out after render. Existing Issues projection remains part of the same Summary response.
- The Candidate Submission column defaults after Processing Status and before Issues, contains no actions, and behaves like peer columns: persisted drag/reorder, persisted resize and approved-label sorting. The user's saved position is authoritative after the first change.
- Embedded identity/signature validation, maximum-100 server batches, duplicate display-key separation and blank/not-applicable short-circuit remain mandatory.

Legacy retirement boundary and verification

Legacy QR/Electronic presentation and gating may be retained only as inert compatibility transport for historic payload parsing; it cannot veto or enable current Office actions. Current server action flags, Candidate workflow projection, signed-manifest finalisation and canonical route/version authority remain intact. Mandatory regression covers PostgreSQL 17.6/18.1, complete frontend/backend JavaScript, patched-asset Playwright at desktop and narrow viewports, all four Office surfaces, QR/Manual/Electronic route labels, Authorise visibility, Summary interaction and manager-reminder recovery.

No-change and activation boundary

No Candidate business table or public RPC is added. DAILY/WEEKLY economics, rates, pay, charge, VAT, ERNI, margin, Process implementation, invoice, payment, Banking Pay, Policy X, settlement, remittance and production authority are unchanged. Candidate public feature flags remain false until separate activation approval.

Current Decisions

Candidate Daily availability integration

Later-controlling corrected Phase 0 R5 addendum • Sections 42–56

Decision date	16 August 2026
Document status	Corrected Phase 0 R5 ready for independent re-audit
Base document	43-page Final Office Acceptance decisions dated 14 August 2026
R5 verdict	Phase 0 remains pending independent R5 audit. Phase 1A runtime implementation, Phase 2 SQL authoring/installation, Phase 1B, Candidate Daily activation and production are NO-GO. This document grants corrective specification and audit authority only.

Precedence: sections 42-56 supersede the earlier Phase 0 addenda and control only Candidate Daily availability, minimal-change legacy containment/coexistence, Google routing, the additive DB/RPC boundary, route policies, retained specialist functions, complete legacy-client scope and booked-tile timesheet path. All other Candidate workflow, Office, finance, Banking Pay and Policy X decisions remain unchanged.

The original accepted document is reproduced unchanged as pages 1–43 of the combined PDF. This addendum follows it and is the current authority for Candidate Daily availability coexistence.

Precedence

The accepted Candidate App Decisions PDF pages 1–43 remain unchanged. Sections 42–55 below are later-controlling only where they explicitly govern Candidate Daily availability storage, broker/Google coexistence, legacy authentication, Daily capability gating, retained specialist functions and cutover. The original decisions continue to control every other subject, including Candidate DAILY workflows, manager PHONE signing, Office authority, finance and Policy X.

This R5 addendum supersedes every earlier Phase 0 addendum, including R3, in full.

42. Authority and topology

Supabase becomes the canonical candidate-entered availability authority only through a recorded environment/candidate cutover. Google remains a synchronized Master Rota projection during coexistence. The Candidate client speaks only to the public Candidate broker. The public broker uses the existing private Candidate API/service binding, which calls service-owned Supabase RPCs. No second public intermediary, direct app-to-Supabase connection or direct app-to-Google connection is introduced.

43. Legacy compatibility by containment, not modernisation

Do not modernise the legacy app. Contain it. The old Availability browser, UI, login flow, internal msisdn lookup, tile fields, statuses, save controls, mixed per-date outcomes and retained specialist journeys remain unchanged wherever reasonably possible. The temporary browser receives no CloudTMS session/token, canonical Candidate UUID, HMAC secret or direct Candidate API authority. Existing Apps Script remains its server boundary. A small removable compatibility adapter resolves the existing legacy source, creates/reuses stable server-owned operation identity, signs an Apps Script-to-CloudTMS request, and CloudTMS independently maps the approved source identity to exactly one canonical Candidate. No unrelated legacy defect is repaired as part of this integration.

Legacy save keeps mixed accepted/rejected per-date semantics. The accepted subset commits once under a single canonical version and durable receipt. A busy/update-window response cannot claim application before that commit; deferral is explicit and retryable.

44. New-app Daily availability

The new product renders fourteen Daily tiles from one complete active Supabase rota generation overlaid with canonical preferences. It saves availability through an authenticated, versioned, idempotent, all-or-none broker command. Booked and blocked dates are not editable. The route never reads Google. Every result has a correlation ID, stable error code and retry classification.

iOS, Android and first-party browser web are presentation surfaces over the same public Candidate broker contract. None owns independent authorization, availability, Emergency or timesheet business logic. The browser web surface is not an installed PWA and does not reproduce the old browser installation journey.

45. Candidate DAILY timesheets and booked-tile actions

Booked tiles provide closed, server-authored action locators only when the current Candidate action-hub record identity and concurrency token are unambiguous. The token is the accepted opaque 32-character lowercase `row_signature`; Daily does not name a digest algorithm, derive another signature or create a second concurrency authority. The app refreshes the accepted action hub immediately before acting. Missing, ambiguous, stale or moved ownership omits the locator.

Viewing/editing, Save/Recalculate, candidate signing, EMAIL approval and PHONE manager handoff use the accepted Candidate DAILY and Candidate Manager route family. The legacy Apps Script `SEND_TIMESHEET` and shape-detected authorization callback remain old-app compatibility only and cannot authorize the new workflow. Candidate-specific callbacks require signed system authentication or canonical CloudTMS database projection.

Candidate-facing terminology is exact: any action that produces documents to be signed is labelled **“Print documents for signing”**. Legacy/internal action identifiers or labels are never displayed in the Candidate App.

46. Retained Daily specialist functions

Emergency/cannot-attend/leave-early, running-late options/preview/send, DNA/cohort/exclusion rules, tried-calling states, acknowledgements, messages, Past Shifts, Hospital Addresses and Accommodation Contacts remain available to both apps. They share one CloudTMS business/effect authority. New-app access is through individually allowlisted Candidate broker routes; temporary legacy access is through individually allowlisted signed Apps Script adapters that preserve existing response shapes. There is no generic Apps Script action tunnel and no duplicated emergency/specialist authority. Current effective emergency eligibility uses a 600-minute grace for parity. A contradictory 30-minute source comment is non-authoritative until deployed boundary tests and an explicit product decision change the rule.

External effects use stable effect keys and the exact durable owner `private.candidate_daily_external_effect_receipts`. Apps Script must claim an effect before acting and complete it afterwards; it never owns a second receipt authority. A retry checks the database receipt and, where needed, provider state; it does not blindly send again. UNKNOWN is a durable non-success state requiring reconciliation, not permission to resend.

47. Database and version authority

The availability extension is additive and environment-scoped. It contains twelve tables and thirteen service-only RPC owners. The increase from R2 supplies explicit batch replay, source mapping and external-effect authorities; it does not broaden candidate functionality. No legacy browser-session table/RPC family is introduced. One authority-scope row per environment/candidate owns the canonical version. An accepted command locks it, increments once and stamps changed days, receipt and outbox with the same version. Generation publication that clears a preference follows the same lock/increment/stamp rule. Browser roles receive no table/RPC access. Environment comes from trusted deployment context, never request body.

The design count is descriptive, not a license to weaken security. A future count change requires a recorded decision and compatible migration.

48. Rota generation, projection and freshness

There is exactly one ACTIVE fourteen-day generation per environment/candidate. Activation requires fourteen unique consecutive rows and atomically supersedes the old generation. `booking_id` is bounded text, not UUID.

Freshness has accepted canonical, delivered-visible, overlay-proof, effective-required-visible and effective-visible monotonic progress. DEFERRED_OVERLAY advances no delivered cursor and consumes no delivery-failure attempt. A proven current active-generation overlay may satisfy effective visibility while it safely hides the canonical preference; removing or changing it invalidates proof and wakes the parked work. A genuine unprojected visible change or noncontiguous gap remains blocking. Normal new-product reads remain database-only.

49. Route-class policy, global switch and pilot entitlement

The global switch is the exact JSON boolean `candidate_daily_enabled` in `settings_defaults.candidate_app_feature_flags_json`. Missing/null/malformed/read error is false. The accepted bootstrap field `entitlements.daily` is preserved with its pre-existing meaning and is not the new Availability decision.

The additive object `capabilities.daily_availability` is the sole authority for the new Candidate Daily Availability surface. Its `enabled` value is true only when the global switch, explicit current-environment/candidate entitlement, immutable source/candidate binding and Candidate-surface readiness are all true. One private route-policy authority assigns `BASELINE_BOOTSTRAP`, `CANDIDATE_SURFACE`, `LEGACY_COMPAT` or `SIGNED_SYSTEM_SYNC`. Only `CANDIDATE_SURFACE` consults the new-product switch. Legacy compatibility and signed system synchronisation continue under their own validated session/HMAC, source/effect, mode and transition prerequisites while the product flag is false. Missing, malformed, unavailable or unreadable inputs fail closed within the selected policy. If `entitlements.daily` and the new capability differ, the new capability controls Daily Availability. False hides/unmounts Daily on all three new surfaces, leaves Weekly available and denies direct Candidate Daily requests; it does not stop legacy or system continuity.

Entitlement is an explicit private record with environment, candidate, enabled state, validity, actor, timestamp, reason and evidence. It is never inferred from active candidate state, source links, account rows, keys or cohort.

50. Google system trust and replay protection

Google-system routes have no browser CORS or candidate-cookie authority. HMAC v1 signs method, normalized path/query, timestamp, nonce, content digest, idempotency key, correlation ID and raw body bytes exactly as specified by the Phase 0 canonicalization vectors. The private API verifies signature and conditionally consumes a nonce in a dedicated durable versioned prefix. The public broker has neither secret nor replay store. A duplicate nonce is rejected. Signed system calls must supply one exact valid signed correlation ID and it is never replaced. Candidate/browser calls may receive a generated correlation ID before authority processing. Database receipts own business idempotency.

Candidate user sessions and the legacy compatibility boundary are separate trust mechanisms. The legacy browser keeps its existing login; only the Apps Script-to-CloudTMS hop uses Google-system HMAC and nonce authority.

51. Idempotency, receipts and external effects

Idempotency-Key is the sole transport authority for commands; command bodies do not duplicate it. Pure reads do not require it. Same key and same request hash returns the original completed result without another version/outbox/effect. Same key with a different hash conflicts. Receipt state advances IN_PROGRESS -> COMPLETED or IN_PROGRESS -> FAILED_FINAL; terminal result is write-once. A stale IN_PROGRESS owner is recovered under a bounded lease.

Multi-candidate generation publish is per-candidate atomic and returns ordered COMMITTED, REPLAYED or REJECTED outcomes. One candidate failure cannot partially activate that candidate or roll back another candidate already committed.

A multi-item or multi-candidate command also has one immutable batch receipt containing the canonical request hash, deterministic input order, linked item receipts, recovery lease and exact write-once terminal response. Projection claims are commands with a stable claim request ID. The receipt freezes claimant, request hash, target/scope, requested limit, ordered claimed row identities, lease tokens, expiries and terminal claim result. Exact replay returns the same still-valid lease set; a claimant must recover, complete, expire or explicitly reconcile every active lease before new work. Completion requires the exact claimant, lease token and row/version and rejects stale, reassigned or changed duplicate completion.

`private.candidate_daily_external_effect_receipts` remains the one effect authority. For running late, cannot attend, leave early, DNA, acknowledgement and escalation stop it records exact candidate/shift/source-event identity, immutable request hash, idempotency key, first claim, lease owner/token/expiry, attempts, provider request/result evidence, UNKNOWN, terminal result, reconciliation and retention metadata. Same key/hash replays; same key/different hash conflicts before effects; ambiguous provider outcome never blindly retries.

52. Cutover, rollback and evidence gates

Every authority transition is recorded durably with environment, candidate/cohort, prior/new mode, effective time, canonical version, active generation, accepted/visible cursors, in-flight disposition, actor, approver, reason and evidence hash. Cutover and rollback are atomic service operations, never manual flag-only events. Rollback does not create dual authority.

Phase 0 uses replayable sanitized fixtures. Effectful evidence is listed separately and requires explicit TEST mutation/communication approval, synthetic identifiers, cleanup and no-production proof. Rollout requires the measurable soak/error budget frozen in the test plan.

Before Apps Script editing/deployment or Phase 1B Google closure, an authorized read-only gate records effective project file order, deployed version, hashes, triggers, manifest, property names, winning duplicate functions and the complete Master Availability consumer/writer graph.

53. Phase structure and activation

R5 is awaiting independent Phase 0 re-audit. Phase 1A runtime implementation, Phase 2 SQL authoring/installation, Phase 1B, Google changes and activation remain no-go until the preceding gate is explicitly passed and authorized. After Phase 0 pass, Phase 1A implements dark broker contracts; Phase 2 implements the additive database/RPC authority under separate TEST mutation authority; Phase 1B implements broker-to-RPC and narrow Google adapters against Phase 2. These are one dependency-controlled work package and are not complete until integrated runtime tests pass together.

The new Candidate App follows the frozen broker contract. Candidate Daily remains inaccessible until global switch, explicit entitlement, identity, freshness, parity, cutover and rollout gates all pass. No Phase 0 statement authorizes migration execution, TEST mutation, Apps Script/Worker/frontend deployment, communication, commit/push or production action.

54. Complete legacy-client preservation boundary

The old Availability browser was audited as a whole. Authentication/password/logout outcomes, resilience/accessibility, local drafts and refresh, all tile/save states, welcome/seen state, Past Shifts, retained content and every Emergency/attendance operation are preserved through either accepted Candidate core routes or explicit Daily routes. The old PWA/browser installation prompt and instructions are not reproduced. The native iOS app is installed through Apple App Store, the native Android app through Google Play, and the first-party browser web application runs without presenting the old install journey. Debug allowlists, console diagnostics and unimplemented queue stubs are not product features.

The old email-timesheet menu action is retired from the new app by explicit user decision. The embedded legacy digital-timesheet implementation is replaced by the already-accepted Candidate DAILY/action-hub workflow; it is not copied as a second workflow. These are the only candidate behaviours found in the static old-client audit whose old implementation is not reproduced. Any newly discovered user-visible behaviour is **USER DECISION REQUIRED** before omission, replacement or addition.

55. Executable closure rules introduced by R5

`CANDIDATE_API_OPENAPI_V1_MERGED_R5.yaml` is the sole implementation contract. The baseline and addendum are build inputs/evidence only. The merged contract must pass semantic OpenAPI 3.1 validation, complete local-reference resolution, unique operation IDs and deep preservation of every non-Daily baseline path/method/operation/security/request/response/error/content type and baseline component. The only accepted baseline operation overlay is the additive bootstrap composition described above.

The exact new feature authority field is `capabilities.daily_availability.enabled`. Candidate source links and key rotation follow Source Identity Canonicalization V1. These plain-text identifiers are included deliberately so the combined Decisions PDF remains searchable and independently testable.

R5 retains one minimal signed legacy-adapter boundary, stable save IDs, one batch/claim receipt, one external-effect receipt, one source-link authority, one cursor model and one transition model. It introduces no legacy browser-session authority. It extends the shared HMAC corpus with method, path, key-version, duplicate-signature and percent-normalisation attacks and requires the unchanged corpus to pass in Worker JavaScript and Apps Script JavaScript. `32_SINGLE_AUTHORITY_AND_NO_DUPLICATION_REGISTER.md` is an implementation stop gate.

The accepted base decisions on pages 1–43 are unchanged. Where an earlier Phase 0 statement names ten tables, nine RPCs, replaceable signed correlation IDs, optional effect receipt storage, session/time-bucket legacy idempotency, a public mirror escape hatch, a combined cohort transition row, `capabilities.daily_enabled`, a universal global gate, duplicated cursor ownership or a 64-character Daily action signature, this R5 addendum is later-controlling and the earlier statement is superseded.

56. R5 semantic closure and certified-source authority

The exact authority mode is `GOOGLE_PRIMARY`, `ROLLBACK_PENDING` or `SUPABASE_PRIMARY`.

Shadow/observation is evidence, not a mode; a completed rollback is recorded as `GOOGLE_PRIMARY` with immutable rollback history. `private.candidate_daily_authority_scopes` owns only authority mode, canonical version, active-generation pointer and transition reference. `private.candidate_daily_sync_state` alone owns `accepted_canonical_cursor`, `required_visible_cursor`, `delivered_visible_cursor`, `overlay_proof_cursor` and `effective_visible_cursor`; readiness requires effective visible progress to meet required visible progress.

Every candidate-specific legacy adapter request is server-to-server, HMAC/nonce protected and contains only the approved `candidate_source_hmac` plus factual operation data. Apps Script may retain its existing internal `msisdn` resolution temporarily, but the browser cannot send a canonical Candidate UUID or choose a CloudTMS source. CloudTMS independently resolves the source HMAC to exactly one Candidate and rejects missing, ambiguous or mismatched mappings before business work. Stable request identity is created and retained at the Apps Script adapter boundary before first submission, allowing exact replay without a legacy-browser patch.

HMAC v1 uses real raw URL/header/body parser paths and rejects malformed percent/UTF-8, controls, encoded separators, dot/empty segments, duplicate/ambiguous headers, CRLF and framing ambiguity. Source Identity V1 uses the explicit code-point normalizer in section 27 and identical canonical bytes across languages. Each of the twenty-five operations has its own exact status/error/retry triples. Every closure fixture has a stable mandatory ID and complete precondition/result/postcondition, including every retained effect/state combination and the minimal-change adapter boundary.

The unredacted user-certified Apps Script sources are authority for static function identity and hashes but are excluded from this distribution because they contain sensitive literals. The pack contains line-order-preserving sanitized sources, source hashes and a function-index equality proof. `ai_startDailyPings` occurs only as a menu reference and has no declaration in either certified source. It is therefore an unimplemented legacy reference, creates no Candidate requirement, and is not implemented or revived by R5. A later authorised effective-project read-only inventory must classify its deployed state before any separate repair/removal decision.

R5 remains documentation and executable-contract evidence only. It performs no Apps Script edit, Worker change, SQL authoring/installation, feature enablement, TEST mutation or production action. Independent Phase 0 acceptance remains mandatory before Phase 1A runtime work.

Implementation-start determination

Corrected Phase 0 R5 remains pending independent audit. Phase 1A runtime implementation, Phase 2 SQL authoring or TEST installation, Phase 1B Google or broker integration, Candidate Daily activation and production remain NO-GO. Only independent re-audit and any resulting corrective specification work may proceed from this document.

No database migration or data/configuration mutation, Candidate Daily flag change, Google edit/execution/deployment, Worker/frontend deployment, communication send, commit, push, pull request or production action is authorized by this document.

The supervised source-identity artifact and live Apps Script file-order/deployment/trigger/property/winning-function inventory remain gates before identity backfill, Google edits and Google closure. Installing Phase 2 in TEST still requires explicit migration/mutation authority. Candidate activation also requires the global exact-true switch, explicit entitlement, cutover ledger and quantitative soak gates.

Current Decisions

Candidate Daily availability integration

Later-controlling Phase 1A R6 addendum • Sections 57–64

Authority	Current fact
Decision date	16 August 2026
Base authority	Accepted 61-page Phase 0 R5 Decisions PDF; AV-001–AV-154 remain controlling
R6 additions	Google Evidence Gate complete; AV-155–AV-180; Phase 1A source implemented dark
Runtime status	Local source/tests only; no Worker deployment, SQL installation, Google change or feature enablement
Next gate	Independent R6 review before Phase 2 additive SQL/RPC authoring

Precedence: Sections 57–64 add evidence and Phase 1A implementation decisions. They do not weaken or replace AV-001–AV-154. If a historical status statement says Phase 1A is not yet authorised, the accepted independent R5 GO plus this R6 implementation record supersede only that status; all substantive R5 constraints remain intact.

The first 61 pages are the accepted R5 Decisions document reproduced unchanged in the combined PDF. This addendum begins on the next page and is the current authority for the effective Google evidence and Phase 1A source state.

57. Google Evidence Gate

The authorised read-only Google Evidence Gate is complete for the Availability API and NEW MASTER ROTA System. No Sheet data, Apps Script file, manifest, property, trigger, deployment or OAuth configuration was changed; no function was executed. Property values and unredacted source remain excluded from audit distribution.

System	Effective source/deployment evidence
Availability API	Sheet 1BSom...; current Head SHA-256 eacd1875...bbb3b3f; exact certified-source match; active web version 215 matches Head; 0 installed triggers; 50 property names inventoried without values.
NEW MASTER ROTA	Sheet 1eEnr...; current Head SHA-256 c3ae9c48...19fa0a8; exact certified-source match; active web version 100 SHA-256 f41dad2e...682099d differs from Head; 12 trigger entries; 28 property names inventoried without values.

- Effective project file order and duplicate-function ownership are known and must be rechecked immediately before a later Google edit.
- Master trigger execution uses current Head while the deployed web version is older; Phase 3 must distinguish trigger-source and web-deployment authority.
- ai_startDailyPings has no declaration or installed trigger. Its one historical reference is not revived or repaired by Candidate Daily.
- The Google projects do much more than Candidate Daily; unrelated functions remain outside scope and untouched.

Binding legacy rule: Do not modernise the legacy app. Contain it. Preserve the old browser/UI/login and internal msisdn behaviour; strengthen only the later trusted server-to-server Apps Script-to-CloudTMS boundary.

58. Phase 1A source authority

Phase 1A implements the frozen public/private transport and policy contracts from the sole merged R5 OpenAPI. It does not implement the Phase 2 database/RPC authority or any Phase 3 Google adapter. The exact baseline is cloudtms-backend origin/test commit 5386d3d2504d86a0366d66f4096a2f7a8912b2e9.

Source owner	Bounded responsibility
candidate-daily-contract-v1.js	Closed 24-route catalogue; policy, limits, correlation, idempotency, capability and error authority.
candidate-daily-hmac-v1.js	Raw-target canonicalisation; HMAC v1; key overlap; private R2 nonce owner and cleanup.
candidate-daily-phase1a.js	Additive disabled bootstrap and effect-free dark dispatch.
candidate-app-backend.js	Authenticated Candidate Daily dispatch plus additive bootstrap only.
candidate-private-worker.js	Private signed-system prefix, service auth, HMAC verification and nonce cleanup.
candidate-broker.js	Credential-free signed-system forwarding; Candidate transport/rate/deadline boundary; stable safe responses.
candidate-broker/wrangler.jsonc	Four TEST rate-limit bindings; no HMAC secret value.

Dark means safe: all Candidate Daily calls are globally disabled, signed system calls cannot reach business work, and no Daily table/RPC or Google executor exists. A successful HMAC check is not product enablement.

59. Routes, policies and limits

The runtime catalogue matches all 24 new merged-R5 operations exactly: 11 Candidate routes and 13 trusted Google-system routes. Existing bootstrap is the additive 25th Daily-related merged operation.

Route family	Policy/class	Count	Bound
Candidate Daily reads	CANDIDATE_SURFACE / CANDIDATE_DAILY_READ	7	60/min/Candidate; 6 in flight; 32 KiB; 12 s
Candidate Daily commands	CANDIDATE_SURFACE / CANDIDATE_DAILY_COMMAND	4	12/min/Candidate; effects 6/min; 1 operation/effect; 32 KiB; 10/20 s
Legacy compatibility	LEGACY_COMPAT_READ/COMMAND	4	Signed system transport; 120/min/key; 8 in flight; 256 KiB
Signed Google sync	SIGNED_SYSTEM_READ/COMMAND	9	Signed system transport; 120/min/key; 8 in flight; 256 KiB; 10/12/20 s

The four policy authorities are fixed:

- **BASELINE_BOOTSTRAP** preserves the accepted Candidate bootstrap.
- **CANDIDATE_SURFACE** requires readable inputs, global exact true, explicit entitlement, source identity readiness and authority readiness.
- **LEGACY_COMPAT** is independent of the Candidate global flag and requires signed transport, nonce, trusted environment, stable operation identity, approved mapping, compatible mode and transition readiness.
- **SIGNED_SYSTEM_SYNC** is also independent of the Candidate global flag and requires signed transport, nonce, trusted environment, source-scope readiness, compatible mode and transition readiness.

Distributed in-flight enforcement is not simulated with unsafe Worker-isolate counters. The cardinalities are frozen in the route authority; Phase 2 receipts/leases and Phase 1B integration must enforce them before any route can be activated.

60. HMAC, nonce, correlation and replay

The public broker has no Google-system secret and no replay store. It bounds and forwards the exact signed bytes through the existing private service-authenticated binding. The private Worker alone verifies HMAC and atomically consumes the nonce.

Invariant	R6 decision
Signed bytes	Method, normalised path/query, timestamp, nonce, body SHA-256, Idempotency-Key, correlation ULID, blank separator and exact raw body.
Key rotation	One PRIMARY and one optional OVERLAP key slot; unknown/misconfigured IDs fail generically.
Clock	Private-server ±300 seconds.
Framing	Exact Content-Length, UTF-8 JSON content type, no transfer/content encoding, no BOM, strict path/query/header grammar.
Nonce	Atomic create-if-absent under candidate-daily-google-nonces/v1/{environment}/{key_id}/{timestamp}/{nonce}; retained at least ten minutes.
Business retry	Fresh nonce/signature; same caller Idempotency-Key. Phase 2 receipt owns exact business replay.
Correlation	Candidate value may be generated before processing; signed system value is mandatory, signed and never replaced.

No raw password, token, Candidate identity, Script Property value, HMAC secret or Google payload is written into the nonce record. Only bounded creation/expiry metadata and the signed-message digest are retained.

61. Legacy, Master Rota and Emergency coexistence

The temporary legacy system must remain fully functional until the new Candidate App is proven. Phase 1A deliberately changes no legacy client or Google source. The later Phase 3 adapter translates existing server-side behaviour into bounded signed CloudTMS requests and translates results back into the existing browser response shape.

Boundary	Must remain true
Legacy browser	No new login/session/token/UUID/Supabase/HMAC knowledge; existing UI and msisdn lookup preserved.
Availability Apps Script	Smallest server-side compatibility facade; stable request identity across timeout/reload; no direct browser CloudTMS write.
Master Rota	Generation publisher/consumer barriers added only in Phase 3; existing triggers and unrelated consumers preserved.
Emergency/specialist	Both old and new clients ultimately use one CloudTMS receipt/effect authority; no blind resend after uncertainty.
Decommissioning	Legacy browser and adapter are removed only after successful proving and separate authorisation.

- Do not repair unrelated legacy defects during coexistence work.
- Do not infer a Candidate UUID from browser input; the later trusted source mapping resolves and revalidates it server-side.
- Do not revive `ai_startDailyPings` or add a trigger merely because a historical reference exists.
- Do not let Emergency, running-late, cannot-attend, leave-early, DNA or acknowledgement actions acquire a second effect receipt.

62. Verification and safety result

Verification gate	Final result
Focused production-module TAP	13 passed; 0 failed
Complete backend TAP	576 passed; 0 failed
Runtime/OpenAPI route parity	24/24 exact; merged API SHA-256 1e4362f3...f765fa
HMAC Node/Python	3 positive, 2 route-valid, 24 negative, 5 query, 20 raw-parser — PASS in both runtimes
Source identity Node/Python	6 positive, 5 normalisation, 2 malformed, 9 negative, 2 bindings — PASS in both runtimes
R5 pack validator	154 decisions, 25 operations, 4 policies, 63 effects, 28 adapters — PASS
Worker dry builds	Candidate public, Candidate private and normal TEST Worker — PASS
Syntax/diff	All changed JavaScript parses; git diff --check PASS

Safety action	Result
Google data/source/deployment mutation	None
Supabase/SQL/RPC mutation	None
Candidate flag/entitlement change	None
Worker/frontend deployment	None
External effect or communication	None
Production access	None
Finance/Banking Pay/Policy X change	None

The locked dependency installation reported inherited npm advisories. No broad dependency rewrite was authorised or performed. They remain a separate repository-maintenance concern and do not alter the Phase 1A source diff.

63. Decision register extension AV-155–AV-180

AV-001–AV-154 remain in the accepted R5 ledger and matrix. R6 adds 26 decisions. The full row-by-row wording and proof owner are in the R6 compliance matrix included with this PDF.

IDs	Decision family	Disposition
AV-155–AV-160	Google gate, certified source/deployment relation and ai_startDailyPings	Evidenced; no mutation
AV-161–AV-162	Minimal-change legacy containment and dual-client Emergency compatibility	Binding; existing behaviour preserved
AV-163–AV-167	Sole merged OpenAPI, exact routes, additive bootstrap and dark capability	Implemented and tested
AV-168–AV-173	Correlation, idempotency, body/rate/deadline and distributed concurrency ownership	Implemented except durable in-flight owner deferred to Phase 2/1B
AV-174–AV-177	HMAC v1, key rotation, private nonce and separate business replay	Implemented and vector-tested
AV-178–AV-180	No deployment/mutation, Phase 2 boundary and remaining full-app phases	Gates retained

No R6 decision authorises Daily activation, SQL installation, Google editing/deployment, Candidate UI publication, communication effects or production. A later GO must be granted at each named gate.

64. Remaining phases to full implementation

Phase	Required outcome	Current status
Independent R6 review	Audit manifests, source diff, HMAC vectors, Google evidence and AV-001–AV-180.	Next
Phase 2	Author 12 additive tables and 13 service-only RPC owners; PostgreSQL 17/18 disposable verification; separate TEST-install approval.	Not started
Phase 1B	Wire all 24 operations to Phase 2, including receipts/leases, concurrency, Google projection, effects and real public-private-RPC tests.	Blocked on Phase 2
Phase 3	Minimal Availability/Master server-side adapters, consumer barriers, outage/recovery proof; no legacy browser redesign.	Evidence gate complete; edit not authorised
Phase 4	Daily UI for responsive web, iOS and Android from the same broker contract; no client business authority.	Not started
Phase 5	Controlled TEST authority cutover, explicit global/cohort enablement and rollback rehearsal.	Not authorised
Phase 6	Full Emergency/specialist/workflow acceptance through both old and new clients with explicit effect approval.	Not started
Phase 7	Gradual cohorts, continuous gates, then separately authorised legacy app/adaptor decommissioning.	Not started

Current verdict: Phase 1A source is ready for independent review, but the Candidate Daily product remains disabled and incomplete. The full Candidate App includes the already accepted Weekly workflows plus every remaining Daily, Google coexistence, native/web UI, specialist, cutover and rollout phase above.

Current Decisions

Candidate Daily Phase 1A correction

Later-controlling R7 addendum - Sections 65-69

Authority	Current fact
Decision date	16 August 2026
Base authority	Accepted 61-page R5 plus the 9-page R6 addendum; Sections 1-64 remain controlling except where R7 expressly supersedes an operational fact.
R7 purpose	Close all nine bounded findings from the independent R6 audit without beginning Phase 2.
Product state	Candidate Daily remains globally disabled, database-dark, Google-unchanged and effect-free.
Next gate	Independent R7 review; only a GO may release Phase 2 additive SQL/RPC authoring.

R7 is a correction, not an expansion. It changes the public failure boundary, pre-auth system throttling, nonce retention, framing and canonicalisation proofs. It adds no Daily table/RPC, Google adapter, Candidate UI, entitlement or business effect.

65. Independent R6 findings and closure

The independent R6 audit issued a bounded NO-GO for Phase 1A source. It accepted the 24-route catalogue, additive bootstrap success, access topology, HMAC verification order, body/rate/deadline metadata and dark/no-mutation boundary, but identified nine exact transport defects. R7 retains the accepted design and closes each defect directly.

Finding	R7 controlling correction
R6-ERR-001	Every Daily/bootstrap error has exactly ok, error_code, correlation_id, retry_class and required safe message; details is absent or one typed closed variant.
R6-RESP-001	The public broker validates route/status/code/retry/correlation/schema and rebuilds the body; any private drift becomes one conforming generic dependency error.
R6-ORIGIN-001	Disallowed Origin, client and preflight/header policy failures remain public 403 FORBIDDEN / DO_NOT_RETRY.
R6-RATE-001	Signed-system pre-auth traffic consumes both a source-IP bucket and a trusted-key/shared-invalid-key bucket before private HMAC work.
R6-NONCE-001	Ten-minute replay retention starts at successful server consumption, never at the caller-signed timestamp.
R6-CORR-001	A valid signed correlation is preserved; missing/invalid input is rejected at the public pre-auth edge with a newly generated valid response ULID.
R6-FRAME-001	When Content-Length is supplied, Candidate and system paths require exact equality with actual bytes.
R6-HMAC-QUERY-001	Percent-encoded query names/values use explicit ASCII/code-unit tuple ordering in JavaScript and Python.
R6-RAW-001	The deployed contract is stated at the Fetch-observable header boundary; raw pre-normalisation properties are never claimed without a platform-level HTTP probe.

66. Closed response and transport authority

The merged R5 OpenAPI remains the sole API authority. R7 does not edit its route or error matrices. Runtime tests load the frozen 25-operation matrix and compare every permitted status/error/retry triple exactly, including bootstrap.

Boundary	Required behaviour
Daily error	additionalProperties=false; fixed public message; correlation is a valid ULID; no untyped unavailable_reason object.
Public response	Never forwards private JSON bytes. It reconstructs allowlisted public fields and safe headers only.
Nonconforming private body	Returns CANDIDATE_DAILY_NOT_READY/STATUS_CHECK on Candidate routes or DEPENDENCY_UNAVAILABLE/RETRY_AFTER on bootstrap/system routes.
Phase 1A success	No new Daily business success is possible. A wrong or unexpected success schema fails closed to the generic dependency result.
403 policy	Origin, native-client and preflight/header rejection stay 403 FORBIDDEN / DO_NOT_RETRY, never 500 retryable.
Framing	Candidate maximum remains 32 KiB; system maximum remains 256 KiB; supplied declared length must equal bytes read.

Private implementation data cannot cross the public broker merely because it is valid JSON. Internal stack, database, token, storage, diagnostic and unknown future fields all cause safe generic reconstruction.

67. Rate, nonce, HMAC and platform boundary

Invariant	R7 decision
Pre-auth rate	One IP bucket always applies. An accepted PRIMARY/OVERLAP key ID may have its own second bucket; every unverified/unknown ID shares one invalid-key bucket. Rotating attacker labels cannot multiply private work.
Nonce lifetime	R2 uploaded time or the stored server consumption epoch owns age. At 599 seconds it remains; at 600 seconds it is eligible for cleanup, including requests accepted at both +/-300-second clock edges.
Correlation	The HMAC signs a valid supplied ULID. The public edge does not alter it. Missing/invalid signed input never reaches private and the error envelope still carries a valid generated ULID.
Query ordering	Canonical percent-encoded strings are sorted by explicit ASCII/code units, then value; locale collation is prohibited.
Raw headers	Workers can enforce only the Fetch Request/Headers representation they receive. Duplicate lines may already be combined and outer whitespace may be normalised. The verifier rejects the resulting ambiguous/invalid observable value; direct raw-pair vectors remain reference-parser evidence, not a claim that wire bytes survive Cloudflare unchanged.

- No public HMAC secret or nonce store is introduced.
- No unknown key ID receives an independent throttle bucket.
- The R5 signed prefix/body algorithm remains unchanged; only deterministic query ordering and replay-age ownership are corrected.
- Future routes with a non-empty query must use the same corrected Node/Python vectors before activation.

68. Google coexistence and decommission boundary

The user deployed NEW MASTER ROTA current Head as active web-app version 101 on 16 August 2026. That later operational fact supersedes the R6 evidence statement that active version 100 differed from Head. The current Head hash and certified-source relationship remain the recorded authority; Phase 3 must recheck them immediately before any Google edit.

Decommissioning the temporary legacy Availability browser and its LEGACY_COMPAT facade does not decommission the Availability Sheet/Apps Script service, Emergency functions, Master Rota publication, signed system synchronisation, projection/freshness routes or effect authority.

Component	Lifecycle decision
Legacy browser/UI/login	Preserve unchanged during coexistence; remove only after the new Candidate app is proven and separately approved.
LEGACY_COMPAT facade	Temporary server-side translation for the old browser. It may be removed with the old browser after accepted cutover.
Availability Sheet/Apps Script	Continues after browser retirement until its emergency/specialist responsibilities are separately migrated and accepted.
NEW MASTER ROTA	Continues publishing generation/working truth required by Availability and specialist flows; it sends to the signed CloudTMS system boundary as Phase 3 settles.
Emergency/specialist flows	Must work with both old and new clients during coexistence and retain one CloudTMS receipt/effect authority. No flow is silently retired with the old browser.
Final specialist retirement	A separate later decision, migration and acceptance gate; never inferred from Candidate app launch.

69. Decision register AV-181-AV-192 and remaining gate

IDs	Decision family	Current disposition
AV-181-AV-183	Closed Daily/bootstrap errors, public response rebuilding and exact 403 policy	Implemented; adversarially tested
AV-184-AV-188	Pre-auth throttling, consumption-age nonce, correlation, exact framing, ASCII query and honest Fetch boundary	Implemented; Node/Python/platform tests
AV-189	Master Rota active web deployment v101 now represents current Head	User-deployed operational fact; future edit recheck required
AV-190	Legacy browser retirement is separate from continuing Availability/Emergency/Master/system services	Binding coexistence/decommission rule
AV-191	Any R7 TEST deployment remains dark; flags false; no SQL, Google, UI or external effect	Required safety boundary
AV-192	Phase 2 remains the next phase only after independent R7 GO	Not started / separately gated

Current verdict requested: GO or bounded NO-GO for corrected Phase 1A only. Do not infer Phase 2 SQL approval, Google edit/deploy approval, Candidate UI completion, feature enablement, production authority or legacy/specialist decommissioning.